SOFTWARE ENGINEERING / CONTROLLED SAMPLE

ORIONDESK AI

Detailed Application Design Specification

SYSTEM CLASS	Human-supervised knowledge operations
DOCUMENT ID	OD-AI-DDS-001
DESIGN BASELINE	R1.0 / revision 1.3
STATUS	Fictional reference architecture
LANGUAGE	English

All users, datasets, companies, credentials, and procedures are fictional.

ENGINEERING SPECIFICATION | 22 CHAPTERS | VERSIONED API & EVENT CONTRACTS

Reference application: document-grounded AI case resolution, deterministic review gates, and verifiable operational controls.

Document Map

This technical baseline is deliberately written as an implementable, fictional detailed design. Chapters 1-6 define architecture and domains, 7-15 specify data/AI integration and contracts, 16-20 specify experience and operations, and 21-22 define verification and lifecycle. All numbers are design assumptions, not measured production performance.

The table of contents contains chapter and section anchors; subsection numbering is embedded directly in the corresponding pages. Figures are normative illustrations of boundaries, not automatically generated implementation artifacts.

Document Map 2

Architecture at a Glance 7

01 Document Control and Design Baseline 8

1.1 Document Governance . . . 8
1.2 System Boundaries . . . 9
1.3 Engineering Decision Record . . . 9
1.4 Component and Contract Register . . . 10
1.5 Failure Modes and Acceptance Evidence . . . 10

02 Product Scope and User Journeys 11

2.1 Actors and Responsibilities . . . 11
2.2 Case Lifecycle Use Cases . . . 12
2.3 Acceptance Boundaries . . . 12
2.4 Component and Contract Register . . . 13
2.5 Failure Modes and Acceptance Evidence . . . 13

03 System Context and Container Architecture 15

3.1 Context Boundaries . . . 15
3.2 Logical Containers . . . 16
3.3 Request and Event Flows . . . 16
3.4 Component and Contract Register . . . 17
3.5 Failure Modes and Acceptance Evidence . . . 17

04 Runtime Deployment Topology 18

4.1 Network Segmentation . . . 18
4.2 Execution Profiles . . . 19
4.3 Environment Parity . . . 19

4.4 Component and Contract Register . . . 20
4.5 Failure Modes and Acceptance Evidence . . . 20

05 Identity, Tenancy and Authorization 21

5.1 Authentication Flow . . . 21
5.2 Authorization Model . . . 22
5.3 Tenant Isolation . . . 22
5.4 Component and Contract Register . . . 23
5.5 Failure Modes and Acceptance Evidence . . . 23

06 Workspace and Case Domain Model 24

6.1 Aggregate Boundaries . . . 24
6.2 State Machines . . . 25
6.3 Business Rules . . . 25
6.4 Component and Contract Register . . . 26
6.5 Failure Modes and Acceptance Evidence . . . 26

07 Connector Management and Source Sync 27

7.1 Connector Contract . . . 27
7.2 Incremental Synchronization . . . 28
7.3 Rate and Error Controls . . . 28
7.4 Component and Contract Register . . . 29
7.5 Failure Modes and Acceptance Evidence . . . 29

08 Document Extraction and Normalization 30

8.1 Input Validation . . . 30
8.2 Extraction Pipeline . . . 31
8.3 Provenance and Quality . . . 31
8.4 Component and Contract Register . . . 32
8.5 Failure Modes and Acceptance Evidence . . . 32

09 Search Index and Grounded Retrieval 34

9.1 Index Schema . . . 34
9.2 Query Processing . . . 35
9.3 Grounding Guarantees . . . 35
9.4 Component and Contract Register . . . 36
9.5 Failure Modes and Acceptance Evidence . . . 36

10 Model Gateway and Prompt Lifecycle 37

10.1 Model Routing . . . 37
10.2 Prompt Construction . . . 38
10.3 Budget and Safety . . . 38
10.4 Component and Contract Register . . . 39
10.5 Failure Modes and Acceptance Evidence . . . 39

11 Agent Orchestration and Tool Access 40

11.1 Plan and Run State . . . 40
11.2 MCP and A2A Boundaries . . . 41
11.3 Control and Failure Policy . . . 41
11.4 Component and Contract Register . . . 42
11.5 Failure Modes and Acceptance Evidence . . . 42

12 Policy Decisions and Human Approval 44

12.1 Deterministic Decision Rules . . . 44
12.2 Review Queue . . . 45
12.3 Publication Gate . . . 45
12.4 Component and Contract Register . . . 46
12.5 Failure Modes and Acceptance Evidence . . . 46

13 Workflow, Queues and Event Semantics 48

13.1 Messaging Contracts . . . 48
13.2 Saga Coordination . . . 49
13.3 Retry and Dead Letters . . . 49
13.4 Component and Contract Register . . . 50
13.5 Failure Modes and Acceptance Evidence . . . 50

14 Relational Data and Object Storage Design 51

14.1 Schema and Constraints . . . 51
14.2 Transaction Strategy . . . 52
14.3 Object and Cache Layout . . . 52
14.4 Component and Contract Register . . . 53
14.5 Failure Modes and Acceptance Evidence . . . 53

15 Public API and Internal RPC Contracts 54

15.1 REST Semantics . . . 54
15.2 Streaming and Notifications . . . 55
15.3 Schema Governance . . . 55

15.4 Component and Contract Register . . . 56
15.5 Failure Modes and Acceptance Evidence . . . 56

16 User Interface, Accessibility and Interaction 57

16.1 Navigation and Information Design . . . 57
16.2 Interaction Models . . . 58
16.3 Accessibility and Localization . . . 58
16.4 Component and Contract Register . . . 59
16.5 Failure Modes and Acceptance Evidence . . . 59

17 Application Security and Data Governance 61

17.1 Threat Model . . . 61
17.2 Data Classification and Privacy . . . 62
17.3 Audit and Cryptographic Controls . . . 62
17.4 Component and Contract Register . . . 63
17.5 Failure Modes and Acceptance Evidence . . . 63

18 Observability, Cost and Service Reliability 64

18.1 Telemetry Model . . . 64
18.2 SLO and Alert Rules . . . 65
18.3 FinOps and Auditability . . . 65
18.4 Component and Contract Register . . . 66
18.5 Failure Modes and Acceptance Evidence . . . 66

19 Performance, Capacity and Resilience 68

19.1 Workload and Capacity . . . 68
19.2 Backpressure and Quotas . . . 69
19.3 Recovery Design . . . 69
19.4 Component and Contract Register . . . 70
19.5 Failure Modes and Acceptance Evidence . . . 70

20 Deployment, Configuration and Release Engineering 71

20.1 Infrastructure as Code . . . 71
20.2 CI/CD and Supply Chain . . . 72
20.3 Release Decision Gates . . . 72
20.4 Component and Contract Register . . . 73
20.5 Failure Modes and Acceptance Evidence . . . 73

21 Test Strategy and Quality Evaluation 74

21.1 Deterministic Verification . . . 74
21.2 AI Evaluation Harness . . . 75
21.3 Acceptance and Release Gates . . . 75
21.4 Component and Contract Register . . . 76
21.5 Failure Modes and Acceptance Evidence . . . 76

22 Operations, Migration and Runbooks 78

22.1 Initial Data Onboarding . . . 78
22.2 Incident Runbooks . . . 79
22.3 Decommission and Exit . . . 79
22.4 Component and Contract Register . . . 80
22.5 Failure Modes and Acceptance Evidence . . . 80

Appendix A Domain State and API Catalog 82

A.1 Case and Run States . . . 82
A.2 REST Resource Register . . . 83
A.3 Canonical Error Envelope . . . 84

Appendix B Canonical Data Definitions 85

B.1 Relational Entity Catalog . . . 85
B.2 DDL Reference . . . 86

Appendix C Event and Tool Protocols 87

C.1 Event Catalog . . . 87
C.2 A2A Task Envelope and MCP Tool Contract . . . 87

Appendix D Threats, Controls and Verification 88

D.1 Security Exit Criteria . . . 88

Appendix E Verification Matrix and Test Data 89

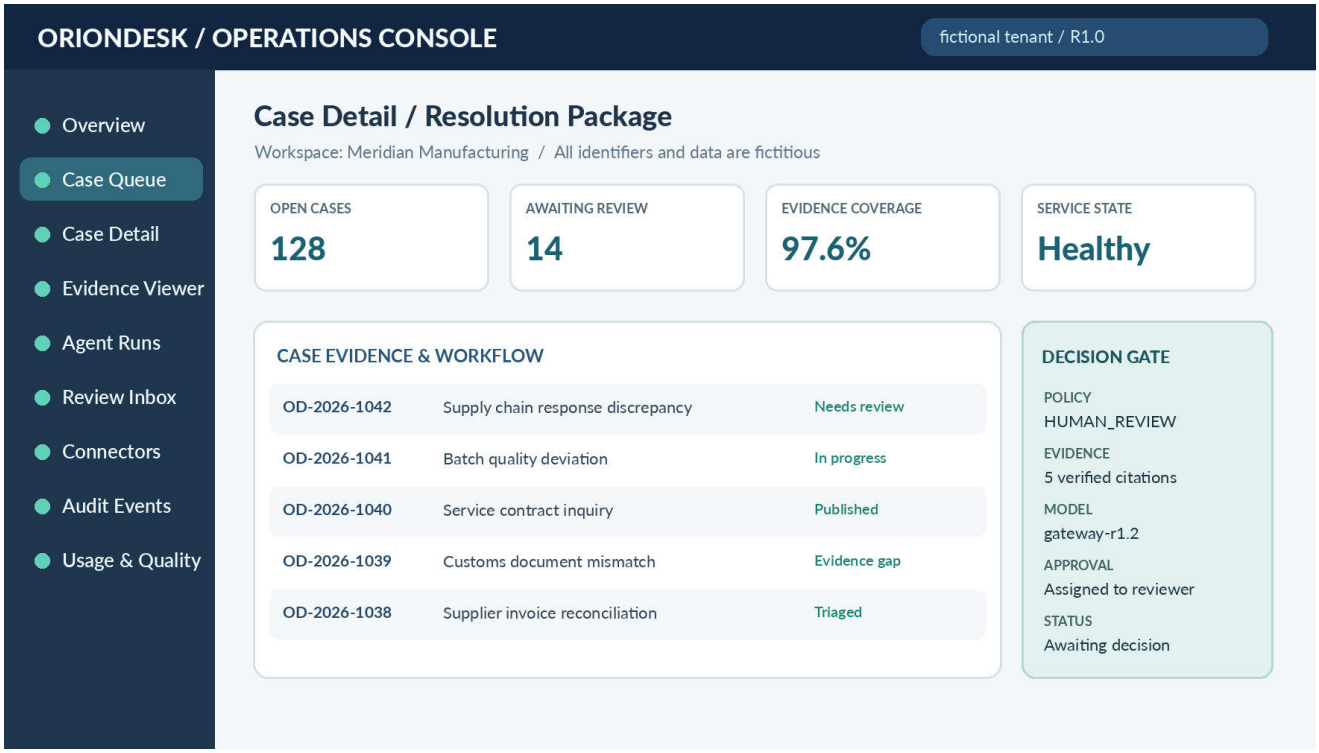
E.1 Test Fixture Principles . . . 89
E.2 Minimum release test pack . . . 89

Appendix F Configuration and Runbook Examples 90

F.1 Runbook: delayed document indexing . . . 90
F.2 Open implementation questions . . . 90

Architecture at a Glance

OrionDesk AI takes a case and permitted evidence through ingestion, retrieval, model generation and a deterministic publication gate. The browser never sends arbitrary tool definitions to the orchestrator. Approval is bound to the reviewed artifact hash, and every cited answer can be traced to immutable source versions.



Reference UI A - a fictitious case workspace with a visible decision gate.

SYSTEM SAFETY RULE

Untrusted retrieved documents and LLM responses cannot authorize tools, change tenant scope, alter approvals or bypass the versioned deterministic policy engine.

Primary deployment profile: stateless HTTP APIs; PostgreSQL transactional store; private blob/object storage; hybrid vector and keyword search; event queue with a transactional outbox; managed-identity credentials; a scoped LLM gateway; and explicit human-review routes.

01 Document Control and Design Baseline

The controlled baseline defines exactly which application behaviors, interfaces, quality gates, and operational constraints the engineering team must implement. OrionDesk is deliberately fictitious; all endpoints, schemas, metrics and assumptions in this specification are normative only for this sample system.

NORMATIVE INVARIANT

All revised invariants must be linked to at least one negative test.

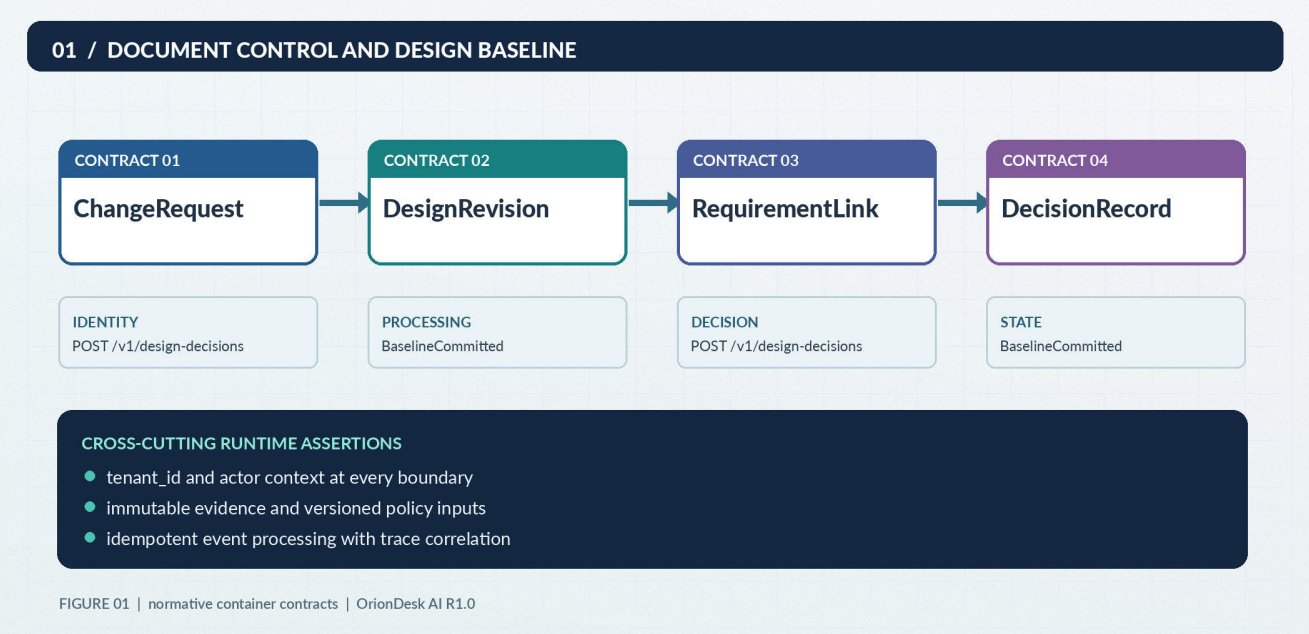


Figure 1.1 - logical components, boundary contracts and control assertions for document control and design baseline.

1.1 Document Governance

1.1.1 Purpose, audience, and authority

The specification is intended for backend, frontend, security, data-platform, test and SRE engineers. Requirement IDs are traceable into API contracts and executable acceptance cases. Decisions in this baseline supersede informal design discussions; changes require an architecture-decision record.

At the interface boundary, ChangeRequest records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/design-decisions must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event BaselineCommitted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

1.1.2 Versioning and change control

The baseline is labeled release R1.0, design revision 1.3. Proposed changes carry impact scores for behavior, data migration, threat surface and operating cost; an approved record increments the minor revision while incompatible protocol changes increment the major revision.

At the interface boundary, DesignRevision records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/design-baselines/{id} must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event BaselineCommitted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

1.2 System Boundaries

1.2.1 Assumptions and exclusions

OrionDesk processes enterprise knowledge and user-submitted cases, not physical automation or irreversible financial transactions. The platform does not fine-tune foundation models, perform unrestricted browsing, or grant agents administrative cloud permissions.

At the interface boundary, RequirementLink records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/design-decisions must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event BaselineCommitted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

1.2.2 Design notation and traceability

Solid arrows denote synchronous request/reply; dashed arrows denote asynchronous events. A control labeled OBLIGATORY is an acceptance criterion, while configurable numeric thresholds are explicitly versioned policy. IDs use namespaces REQ, API, EVT, SEC and TST.

At the interface boundary, DecisionRecord records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/design-baselines/{id} must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event BaselineCommitted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

Design checkpoint 1.2: stateful components must reject stale or unauthorized writes before publishing BaselineCommitted; integration tests assert that rejected actions leave business state unchanged.

1.3 Engineering Decision Record

1.3.1 Non-negotiable architecture choices

Case state is stored in PostgreSQL; documents remain in encrypted blob storage; a searchable derivative index is eventually consistent. The AI orchestrator has no direct database credentials and receives narrow scoped APIs.

At the interface boundary, ChangeRequest records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/design-decisions must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event BaselineCommitted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

1.3.2 Outstanding decisions and constraints

Cross-region active/active mutation, multilingual OCR beyond English, and customer-managed model weights are deferred. A future revision must resolve per-tenant encryption-key isolation against key-rotation throughput before enterprise general availability.

At the interface boundary, DesignRevision records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/design-baselines/{id} must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event BaselineCommitted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

1.4 Component and Contract Register

The following bounded-context register identifies implementation ownership and the minimum verification surface for this chapter. It is intentionally specific enough to support a backlog of interface-level tests.

Component / interface	Contract role	Required invariant
ChangeRequest	Owner aggregate	UUIDv7 + tenant scope
DesignRevision	Immutable derivative	SHA-256 source/ revision
RequirementLink	Policy-bound control	Actor and role predicate
DecisionRecord	Operational ledger	Event ID + trace context
API surface	POST /v1/design-decisions	OAuth audience + idempotency policy
Secondary API	GET /v1/design-baselines/{id}	Schema contract / bounded errors
Published event	BaselineCommitted	Versioned envelope / outbox

1.5 Failure Modes and Acceptance Evidence

Failure scenario A: a duplicate BaselineCommitted arrives after a network retry. The consumer checks its event ledger and aggregate revision, records a duplicate outcome, and returns without reapplying the mutation. Failure scenario B: a caller changes tenant or document permissions between search and publication; the publish gate recomputes its authorization and rejects stale evidence.

Acceptance evidence: one audit record for the accepted state transition, stable error codes for denied operations, tenant-scoped traces, and an implementation test proving this chapter invariant: All revised invariants must be linked to at least one negative test.

02 Product Scope and User Journeys

OrionDesk AI is a human-supervised case-resolution platform: it ingests enterprise documents, searches permitted knowledge, drafts grounded responses, and routes uncertain or sensitive actions to authorized reviewers.

NORMATIVE INVARIANT The system shall not publish a response from an unapproved high-risk run.

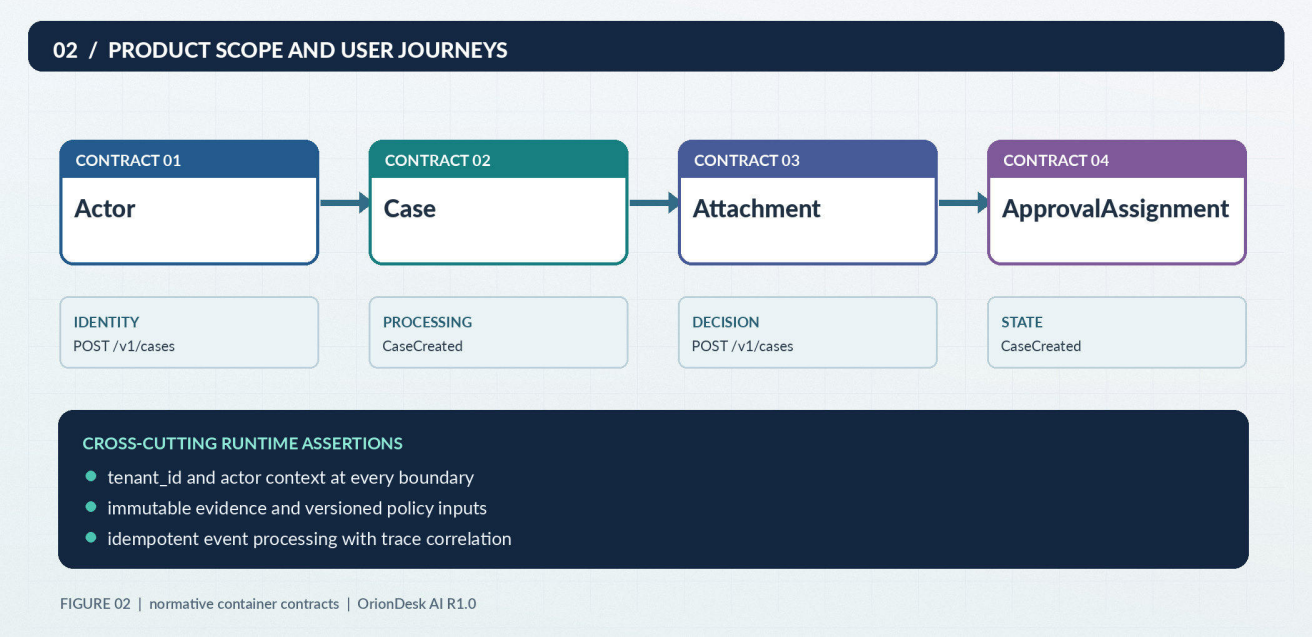


Figure 2.1 - logical components, boundary contracts and control assertions for product scope and user journeys.

2.1 Actors and Responsibilities

2.1.1 User archetypes

The Analyst opens a case and evaluates evidence; the Reviewer approves or rejects AI-generated recommendations; the Workspace Admin manages connectors and policy; the Auditor obtains immutable evidence without editing case content.

At the interface boundary, Actor records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/cases must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event CaseCreated must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

2.1.2 Permission-sensitive journeys

An analyst may request a draft but cannot approve their own high-risk recommendation. Reviewer selection is by policy and org role. An auditor sees decision metadata, prompt-template digests and access events, subject to redacted content scope.

At the interface boundary, Case records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/cases/{caseId}/runs must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event CaseCreated must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

2.2 Case Lifecycle Use Cases

2.2.1 Create and classify a case

A case begins in NEW, receives attachments and business context, then passes policy-aware classification. An asynchronous classification job attaches labels, confidences and provenance; the user can correct labels with a reason code.

At the interface boundary, Attachment records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/cases must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event CaseCreated must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

2.2.2 Resolve with evidence and approval

The analyst requests a grounded answer. Retrieval, generation, policy decision and reviewer approval are separate records. The final reply is published only when required evidence exists and the approval policy is satisfied.

At the interface boundary, ApprovalAssignment records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/cases/{caseId}/runs must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event CaseCreated must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

Design checkpoint 2.2: stateful components must reject stale or unauthorized writes before publishing CaseCreated; integration tests assert that rejected actions leave business state unchanged.

2.3 Acceptance Boundaries

2.3.1 Normal success path

A valid request returns a case identifier within 300 ms at P95 under the stated test load; an AI run becomes terminal within the configured maximum or yields a recoverable timeout state.

At the interface boundary, Actor records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/cases must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event CaseCreated must be visible through correlated logs and the audit record without placing source

document text in diagnostic telemetry.

2.3.2 Abuse and exception paths

Oversized uploads, prompt injection, cross-tenant identifiers, stale approval decisions and ungrounded recommendations must fail closed and expose stable, non-sensitive error codes. Partial processing must never be misrepresented as an approved answer.

At the interface boundary, Case records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/cases/{caseId}/runs must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event CaseCreated must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

2.4 Component and Contract Register

The following bounded-context register identifies implementation ownership and the minimum verification surface for this chapter. It is intentionally specific enough to support a backlog of interface-level tests.

Component / interface	Contract role	Required invariant
Actor	Owner aggregate	UUIDv7 + tenant scope
Case	Immutable derivative	SHA-256 source/ revision
Attachment	Policy-bound control	Actor and role predicate
ApprovalAssignment	Operational ledger	Event ID + trace context
API surface	POST /v1/cases	OAuth audience + idempotency policy
Secondary API	POST /v1/cases/{caseId}/runs	Schema contract / bounded errors
Published event	CaseCreated	Versioned envelope / outbox

2.5 Failure Modes and Acceptance Evidence

Failure scenario A: a duplicate CaseCreated arrives after a network retry. The consumer checks its event ledger and aggregate revision, records a duplicate outcome, and returns without reapplying the mutation. Failure scenario B: a caller changes tenant or document permissions between search and publication; the publish gate recomputes its authorization and rejects stale evidence.

Acceptance evidence: one audit record for the accepted state transition, stable error codes for denied operations, tenant-scoped traces, and an implementation test proving this chapter invariant: The system shall not publish a response from an unapproved high-risk run.

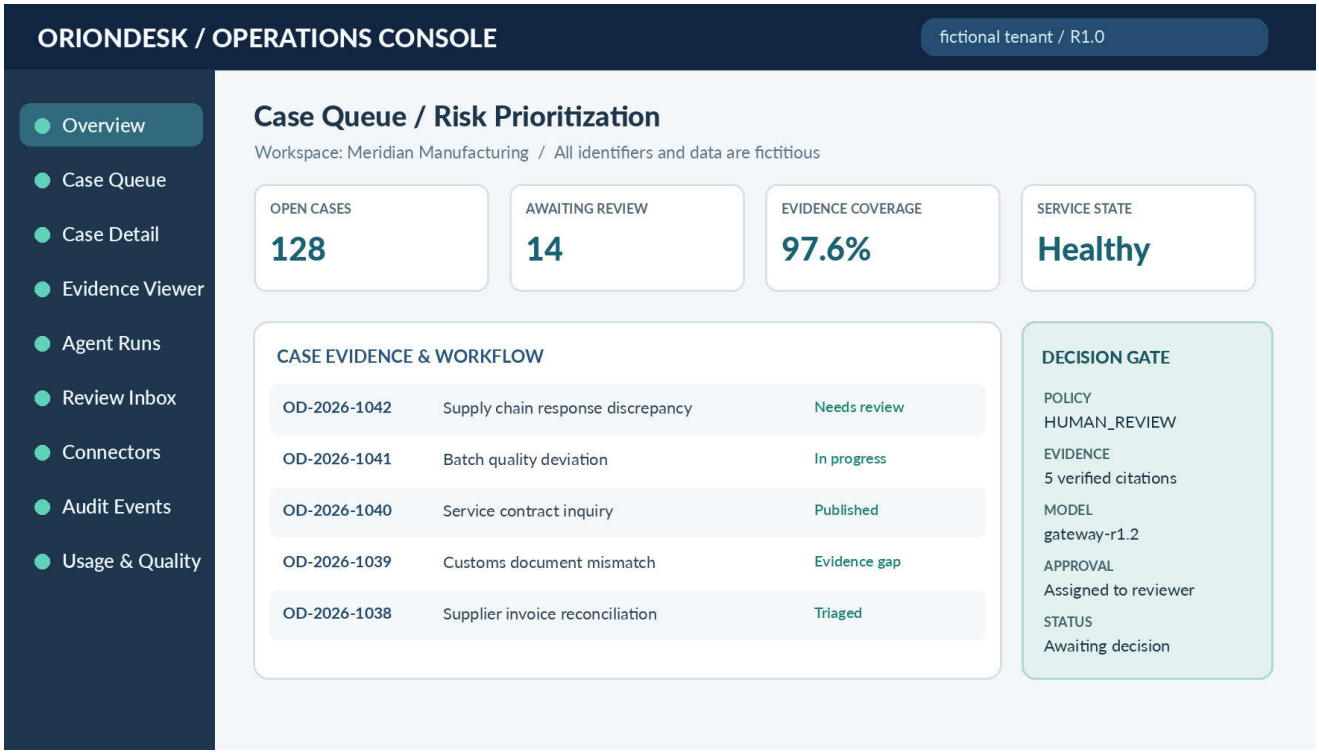


Figure 2.2 - representative operator view for the controlled scenario described in Chapter 2.

03 System Context and Container Architecture

The system has a web client, an edge API, domain services, an orchestration tier, a controlled model gateway, a search subsystem, asynchronous workers and external enterprise connectors.

NORMATIVE INVARIANT Every cross-service write must be idempotent under retries.

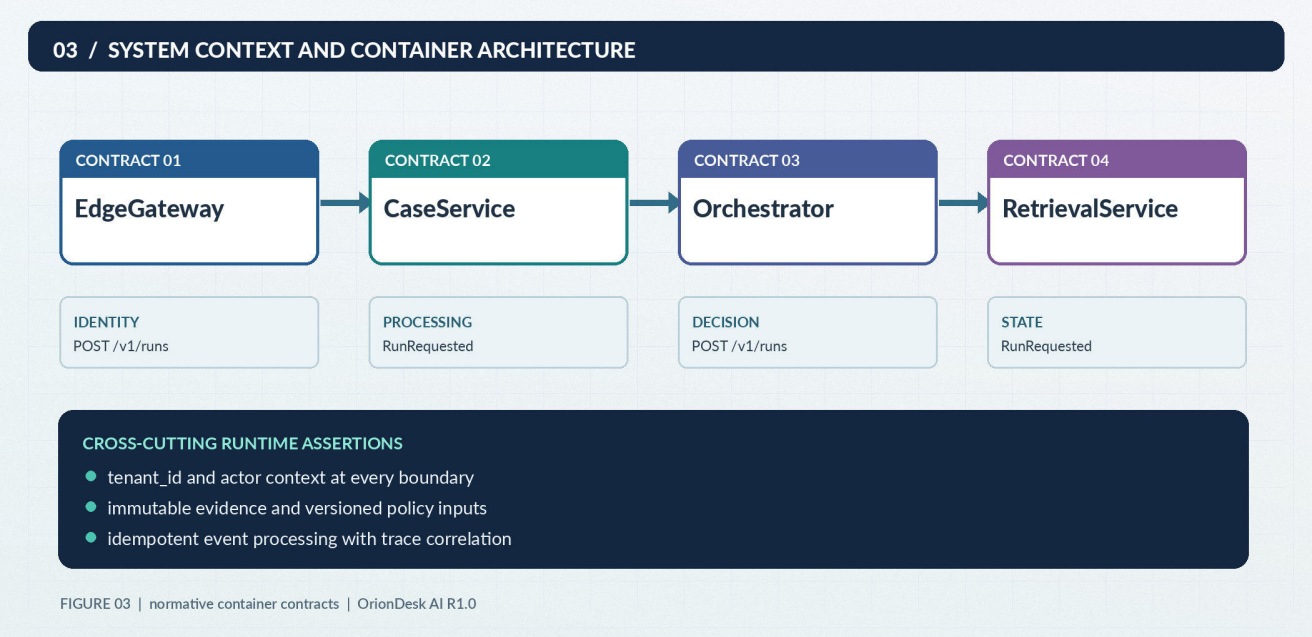


Figure 3.1 - logical components, boundary contracts and control assertions for system context and container architecture.

3.1 Context Boundaries

3.1.1 External actors and trust zones

Browsers enter through the edge with OIDC tokens. Connector workers exchange service credentials with document providers. LLM providers receive only scoped context and structured prompts; they do not receive raw connector tokens or unrestricted database access.

At the interface boundary, EdgeGateway records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/runs must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event RunRequested must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

3.1.2 Contract ownership

Domain teams own case and policy APIs, platform teams own identity propagation and messaging, and the AI platform team owns model gateway contracts. Versioning is additive for nonbreaking changes; removal requires a scheduled migration.

At the interface boundary, CaseService records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/runs/{runId} must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event RunRequested must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

3.2 Logical Containers

3.2.1 Compute decomposition

The API gateway applies authentication and quotas; Case Service owns transactional mutations; Ingestion Service owns document conversion; Retrieval Service returns cited chunks; Orchestrator manages run state; Policy Service issues binding approval requirements.

At the interface boundary, Orchestrator records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/runs must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event RunRequested must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

3.2.2 Storage decomposition

PostgreSQL is authoritative for mutable metadata. Blob storage stores source and normalized artifacts. Vector/keyword index stores nonauthoritative searchable derivatives. Cache contains only versioned ephemeral results with short TTLs.

At the interface boundary, RetrievalService records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/runs/{runId} must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event RunRequested must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

Design checkpoint 3.2: stateful components must reject stale or unauthorized writes before publishing RunRequested; integration tests assert that rejected actions leave business state unchanged.

3.3 Request and Event Flows

3.3.1 Synchronous edges

The browser calls the REST API; internal service calls use mTLS-authenticated HTTP or gRPC where generated contracts reduce serialization ambiguity. Correlation identifiers cross every boundary and remain independent of provider trace identifiers.

At the interface boundary, EdgeGateway records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/runs must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event RunRequested must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

3.3.2 Asynchronous edges

At-least-once message delivery is assumed. Consumers deduplicate by event ID and operation key. Every state-changing workflow uses transactional outbox publication or an explicitly reconciled saga step.

At the interface boundary, CaseService records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/runs/{runId} must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event RunRequested must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

3.4 Component and Contract Register

The following bounded-context register identifies implementation ownership and the minimum verification surface for this chapter. It is intentionally specific enough to support a backlog of interface-level tests.

Component / interface	Contract role	Required invariant
EdgeGateway	Owner aggregate	UUIDv7 + tenant scope
CaseService	Immutable derivative	SHA-256 source/ revision
Orchestrator	Policy-bound control	Actor and role predicate
RetrievalService	Operational ledger	Event ID + trace context
API surface	POST /v1/runs	OAuth audience + idempotency policy
Secondary API	GET /v1/runs/{runId}	Schema contract / bounded errors
Published event	RunRequested	Versioned envelope / outbox

3.5 Failure Modes and Acceptance Evidence

Failure scenario A: a duplicate RunRequested arrives after a network retry. The consumer checks its event ledger and aggregate revision, records a duplicate outcome, and returns without reapplying the mutation. Failure scenario B: a caller changes tenant or document permissions between search and publication; the publish gate recomputes its authorization and rejects stale evidence.

Acceptance evidence: one audit record for the accepted state transition, stable error codes for denied operations, tenant-scoped traces, and an implementation test proving this chapter invariant: Every cross-service write must be idempotent under retries.

04 Runtime Deployment Topology

Production runs in a private cloud network with independent web, API, worker and data subnets; network rules permit only declared flows.

NORMATIVE INVARIANT No datastore is exposed on a public IP address.

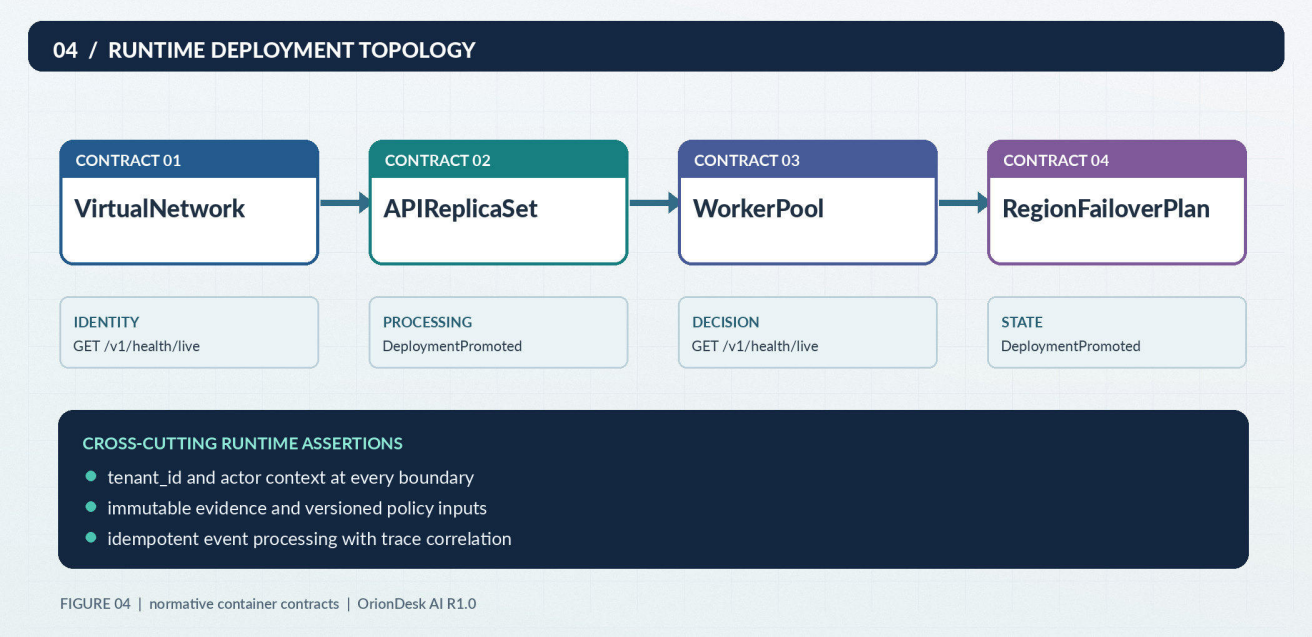


Figure 4.1 - logical components, boundary contracts and control assertions for runtime deployment topology.

4.1 Network Segmentation

4.1.1 Ingress and egress

A managed application gateway terminates public TLS and forwards requests to private API workloads. Workers use NAT-controlled egress to explicit model and connector endpoints. PostgreSQL and object stores reject public endpoints.

At the interface boundary, VirtualNetwork records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/health/live must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event DeploymentPromoted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

4.1.2 Service identity

Managed workload identity replaces static credentials wherever the provider supports it. East-west traffic uses TLS, service-to-service audience checks and scoped IAM roles; a service identity is never shared between deployment units.

At the interface boundary, APIReplicaSet records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/health/ready must validate input before

allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event DeploymentPromoted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

4.2 Execution Profiles

4.2.1 API and worker pools

API replicas scale on utilization and latency, whereas extraction and embedding workers scale on queue age and throughput. GPU inference is not hosted within the application; the model gateway treats providers as external dependencies.

At the interface boundary, WorkerPool records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/health/live must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event DeploymentPromoted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

4.2.2 Regional placement

The R1 profile uses one primary region and one warm recovery region. Persistent writes target the primary; secondary snapshots are restored only under incident command. Disaster-recovery exercises verify object and relational consistency.

At the interface boundary, RegionFailoverPlan records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/health/ready must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event DeploymentPromoted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

Design checkpoint 4.2: stateful components must reject stale or unauthorized writes before publishing DeploymentPromoted; integration tests assert that rejected actions leave business state unchanged.

4.3 Environment Parity

4.3.1 Development, staging and production

Each environment uses the same container images and deployment templates with different isolated secrets and quotas. Staging has synthetic data, test connectors and reduced model spend; production data is forbidden in development.

At the interface boundary, VirtualNetwork records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/health/live must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event DeploymentPromoted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

4.3.2 Release routing

New images are deployed through canary traffic shifts. State-machine and schema compatibility are assessed before traffic movement. A rollback reverses the binary first and invokes compensating data operations only when explicitly supported.

At the interface boundary, APIReplicaSet records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/health/ready must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event DeploymentPromoted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

4.4 Component and Contract Register

The following bounded-context register identifies implementation ownership and the minimum verification surface for this chapter. It is intentionally specific enough to support a backlog of interface-level tests.

Component / interface	Contract role	Required invariant
VirtualNetwork	Owner aggregate	UUIDv7 + tenant scope
APIReplicaSet	Immutable derivative	SHA-256 source/ revision
WorkerPool	Policy-bound control	Actor and role predicate
RegionFailoverPlan	Operational ledger	Event ID + trace context
API surface	GET /v1/health/live	OAuth audience + idempotency policy
Secondary API	GET /v1/health/ready	Schema contract / bounded errors
Published event	DeploymentPromoted	Versioned envelope / outbox

4.5 Failure Modes and Acceptance Evidence

Failure scenario A: a duplicate DeploymentPromoted arrives after a network retry. The consumer checks its event ledger and aggregate revision, records a duplicate outcome, and returns without reapplying the mutation. Failure scenario B: a caller changes tenant or document permissions between search and publication; the publish gate recomputes its authorization and rejects stale evidence.

Acceptance evidence: one audit record for the accepted state transition, stable error codes for denied operations, tenant-scoped traces, and an implementation test proving this chapter invariant: No datastore is exposed on a public IP address.

05 Identity, Tenancy and Authorization

Every request is bound to an authenticated principal and a tenant. Access is evaluated at the resource boundary, not merely in navigation controls.

NORMATIVE INVARIANT No retrieval result may bypass the originating document ACL.

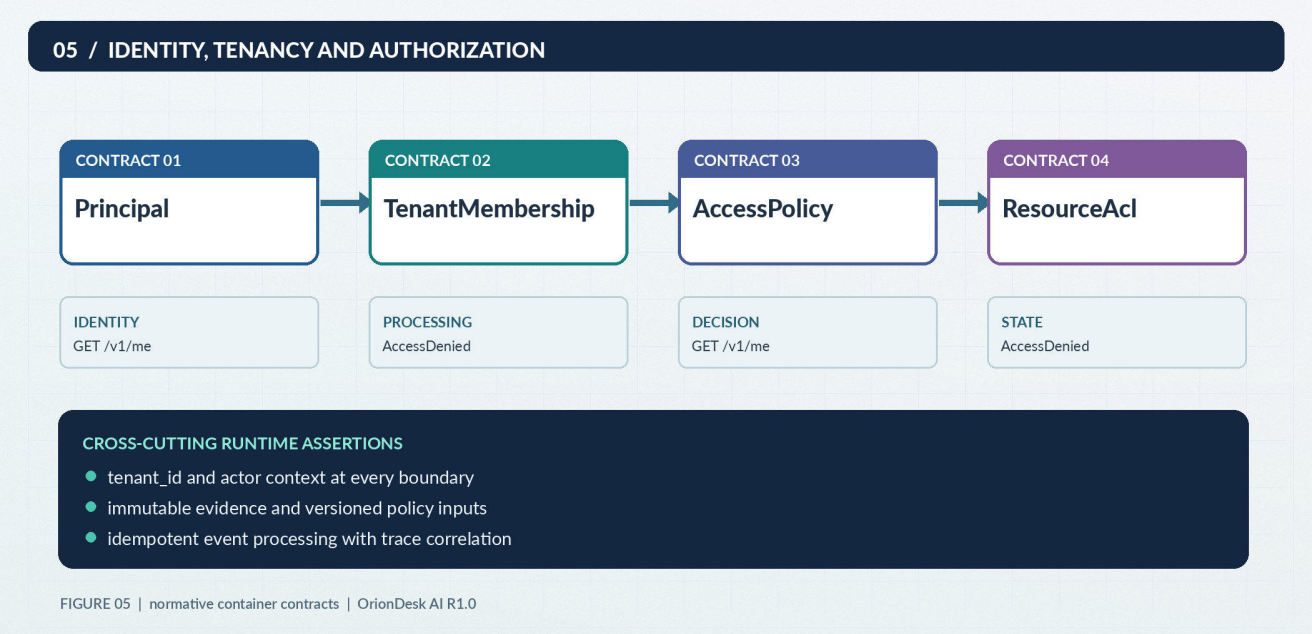


Figure 5.1 - logical components, boundary contracts and control assertions for identity, tenancy and authorization.

5.1 Authentication Flow

5.1.1 OIDC and service tokens

Interactive sessions use the authorization-code flow with PKCE. API access tokens carry issuer, audience, expiry, subject and tenant; the gateway rejects tokens with unexpected algorithms or missing tenancy claims.

At the interface boundary, Principal records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/me must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event AccessDenied must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

5.1.2 Session handling

The browser stores no long-lived refresh tokens in local storage. A backend-for-frontend can issue secure, HttpOnly, SameSite cookies. Service credentials rotate automatically and never appear in traces or model prompts.

At the interface boundary, TenantMembership records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path PUT

/v1/workspaces/{workspaceId}/members must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event AccessDenied must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

5.2 Authorization Model

5.2.1 Roles and attributes

Baseline roles are Analyst, Reviewer, Admin, Auditor and Service. Access combines role, tenant, workspace membership, case sensitivity, document ACL, action and segregation-of-duties constraints.

At the interface boundary, AccessPolicy records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/me must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event AccessDenied must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

5.2.2 Enforcement locations

Edge authorization rejects broad policy violations; domain services re-evaluate resource attributes within the transaction. Retrieval applies document ACL filters before any chunk can be returned to the model.

At the interface boundary, ResourceAcl records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path PUT /v1/workspaces/{workspaceId}/members must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event AccessDenied must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

Design checkpoint 5.2: stateful components must reject stale or unauthorized writes before publishing AccessDenied; integration tests assert that rejected actions leave business state unchanged.

5.3 Tenant Isolation

5.3.1 Database-level controls

Each tenant-owned row has tenant_id, and every request uses tenant-scoped database context with row-level security. Background jobs carry immutable tenant identity in signed envelopes.

At the interface boundary, Principal records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/me must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event AccessDenied must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

5.3.2 Negative assurance

Cross-tenant ID substitution must return the same class of not-found response as an absent ID. Audit events retain the principal and denied resource class without leaking private resource existence.

At the interface boundary, TenantMembership records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path PUT /v1/workspaces/{workspaceId}/members must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event AccessDenied must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

5.4 Component and Contract Register

The following bounded-context register identifies implementation ownership and the minimum verification surface for this chapter. It is intentionally specific enough to support a backlog of interface-level tests.

Component / interface	Contract role	Required invariant
Principal	Owner aggregate	UUIDv7 + tenant scope
TenantMembership	Immutable derivative	SHA-256 source/ revision
AccessPolicy	Policy-bound control	Actor and role predicate
ResourceAcl	Operational ledger	Event ID + trace context
API surface	GET /v1/me	OAuth audience + idempotency policy
Secondary API	PUT /v1/workspaces/{workspaceId}/members	Schema contract / bounded errors
Published event	AccessDenied	Versioned envelope / outbox

5.5 Failure Modes and Acceptance Evidence

Failure scenario A: a duplicate AccessDenied arrives after a network retry. The consumer checks its event ledger and aggregate revision, records a duplicate outcome, and returns without reapplying the mutation. Failure scenario B: a caller changes tenant or document permissions between search and publication; the publish gate recomputes its authorization and rejects stale evidence.

Acceptance evidence: one audit record for the accepted state transition, stable error codes for denied operations, tenant-scoped traces, and an implementation test proving this chapter invariant: No retrieval result may bypass the originating document ACL.

06 Workspace and Case Domain Model

Workspaces group users, policies, connectors and cases; cases are independently versioned aggregates with explicit state transitions.

NORMATIVE INVARIANT Closed cases preserve an immutable lineage of approved outputs.

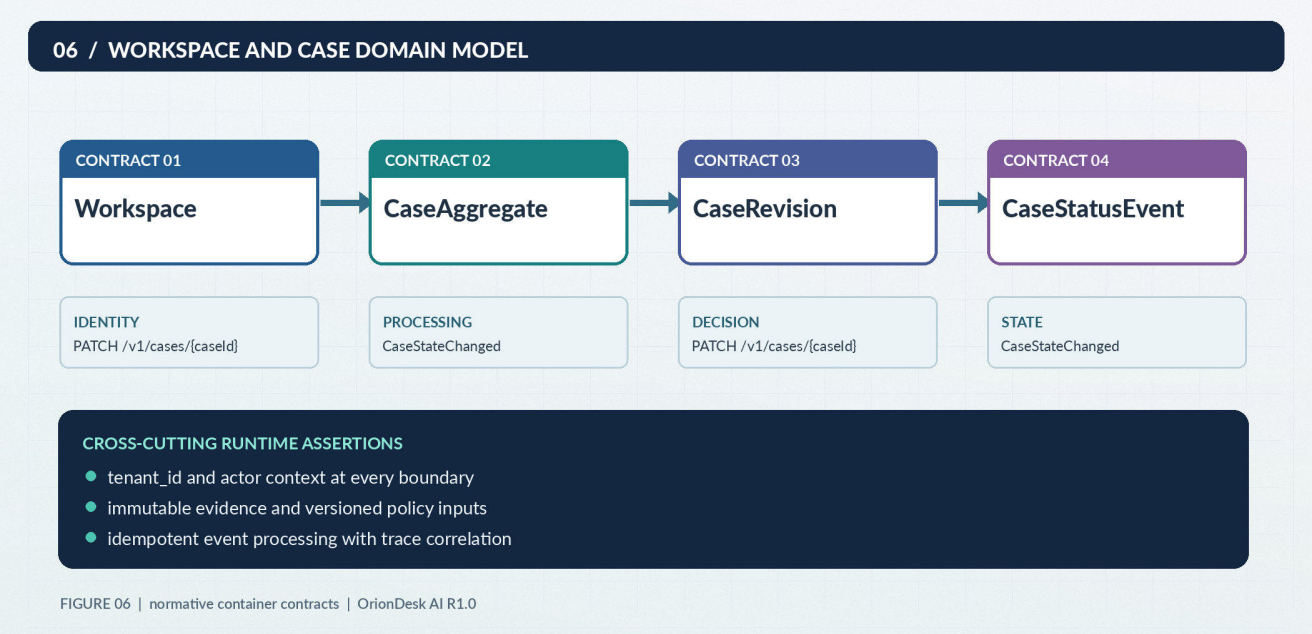


Figure 6.1 - logical components, boundary contracts and control assertions for workspace and case domain model.

6.1 Aggregate Boundaries

6.1.1 Workspace aggregate

Workspace settings include retention class, allowed models, connector credentials references, approved toolsets and reviewer routing. Configuration updates require revision preconditions and produce durable audit records.

At the interface boundary, Workspace records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path PATCH /v1/cases/{caseId} must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event CaseStateChanged must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

6.1.2 Case aggregate

A case stores title, description, priority, sensitivity label, status, owner, current approved result and monotonic revision. Attachments and runs are separate entities joined by immutable identifiers.

At the interface boundary, CaseAggregate records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/cases/{caseId}/close must validate input

before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event CaseStateChanged must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

6.2 State Machines

6.2.1 Case transitions

NEW can transition to TRIAGED; TRIAGED to IN_PROGRESS; IN_PROGRESS to PENDING_APPROVAL or RESOLVED; PENDING_APPROVAL to RESOLVED or IN_PROGRESS. CLOSED is final unless explicitly reopened as a new revision.

At the interface boundary, CaseRevision records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path PATCH /v1/cases/{caseId} must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event CaseStateChanged must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

6.2.2 Concurrency and idempotency

Clients submit If-Match revision conditions. A conflicting update returns CASE_VERSION_CONFLICT with current revision. An idempotency key maps an actor and request fingerprint to one outcome for 24 hours.

At the interface boundary, CaseStatusEvent records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/cases/{caseId}/close must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event CaseStateChanged must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

Design checkpoint 6.2: stateful components must reject stale or unauthorized writes before publishing CaseStateChanged; integration tests assert that rejected actions leave business state unchanged.

6.3 Business Rules

6.3.1 Priority and SLA calculation

Priority is derived from explicit impact and urgency fields, never from model output alone. Business calendars compute deadlines in workspace timezone. Breach prediction is advisory and cannot change contractual deadlines.

At the interface boundary, Workspace records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path PATCH /v1/cases/{caseId} must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event CaseStateChanged must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

6.3.2 Retention and closure

Closure snapshots the approved answer, cited document versions and reviewer decisions. Data retention jobs operate only on eligible closed cases and maintain legal-hold exceptions.

At the interface boundary, CaseAggregate records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/cases/{caseId}/close must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event CaseStateChanged must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

6.4 Component and Contract Register

The following bounded-context register identifies implementation ownership and the minimum verification surface for this chapter. It is intentionally specific enough to support a backlog of interface-level tests.

Component / interface	Contract role	Required invariant
Workspace	Owner aggregate	UUIDv7 + tenant scope
CaseAggregate	Immutable derivative	SHA-256 source/ revision
CaseRevision	Policy-bound control	Actor and role predicate
CaseStatusEvent	Operational ledger	Event ID + trace context
API surface	PATCH /v1/cases/{caseId}	OAuth audience + idempotency policy
Secondary API	POST /v1/cases/{caseId}/close	Schema contract / bounded errors
Published event	CaseStateChanged	Versioned envelope / outbox

6.5 Failure Modes and Acceptance Evidence

Failure scenario A: a duplicate CaseStateChanged arrives after a network retry. The consumer checks its event ledger and aggregate revision, records a duplicate outcome, and returns without reapplying the mutation. Failure scenario B: a caller changes tenant or document permissions between search and publication; the publish gate recomputes its authorization and rejects stale evidence.

Acceptance evidence: one audit record for the accepted state transition, stable error codes for denied operations, tenant-scoped traces, and an implementation test proving this chapter invariant: Closed cases preserve an immutable lineage of approved outputs.

07 Connector Management and Source Sync

Source connectors ingest documents from configured enterprise repositories while preserving source identity, permissions and change history.

NORMATIVE INVARIANT Revoked source access must become effective before the next retrieval.

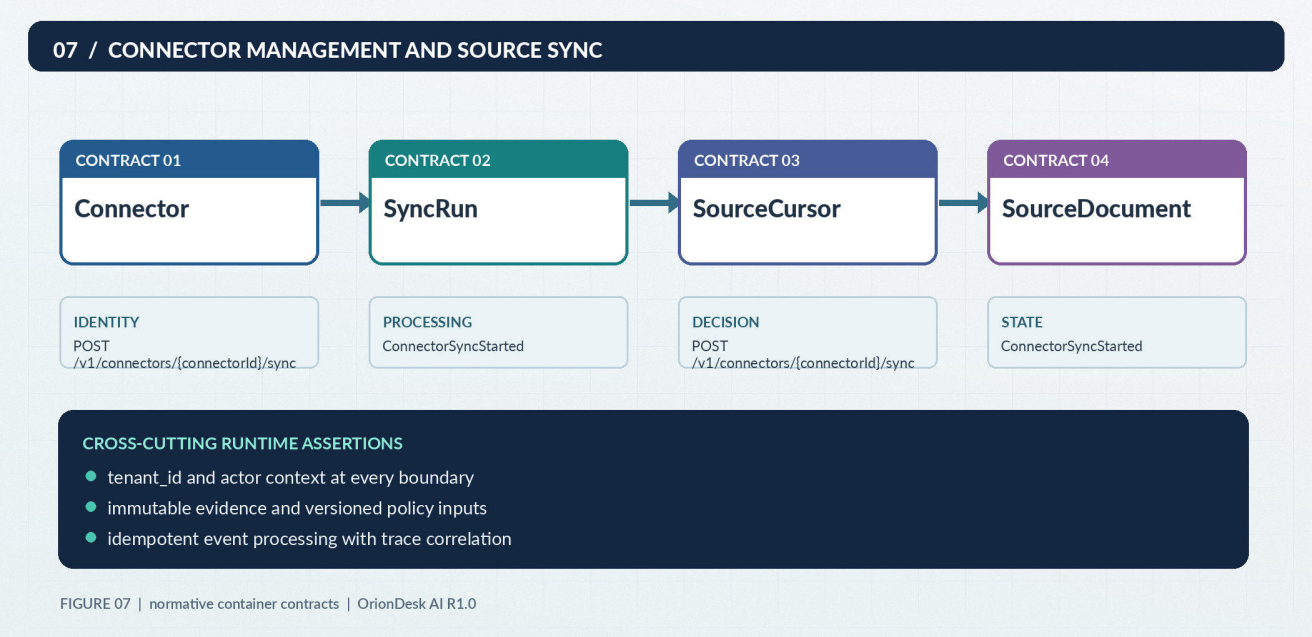


Figure 7.1 - logical components, boundary contracts and control assertions for connector management and source sync.

7.1 Connector Contract

7.1.1 Capability discovery

Each connector advertises list, fetch, delta cursor, ACL and delete support. Unsupported capabilities trigger a lower-trust ingestion mode and an explicit user-visible warning instead of silent assumptions.

At the interface boundary, Connector records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/connectors/{connectorId}/sync must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event ConnectorSyncStarted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

7.1.2 Credential lifecycle

OAuth refresh tokens or service credentials live in a dedicated secret store under workspace-scoped references. Operators can revoke credentials, and queued jobs must fail with CONNECTOR_REAUTH_REQUIRED without exposing tokens.

At the interface boundary, SyncRun records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/connectors/{connectorId}/runs must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event ConnectorSyncStarted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

7.2 Incremental Synchronization

7.2.1 Cursor checkpointing

Every sync run stores a provider cursor, high-watermark and error ledger. A cursor advances only after all preceding items have durable ingestion outcomes; partial batches can retry safely.

At the interface boundary, SourceCursor records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/connectors/{connectorId}/sync must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event ConnectorSyncStarted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

7.2.2 Deletion and ACL changes

A source delete creates a tombstone and schedules index removal. Source ACL changes invalidate retrieval cache entries before new results can be served; stale visibility is treated as a security incident.

At the interface boundary, SourceDocument records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/connectors/{connectorId}/runs must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event ConnectorSyncStarted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

Design checkpoint 7.2: stateful components must reject stale or unauthorized writes before publishing ConnectorSyncStarted; integration tests assert that rejected actions leave business state unchanged.

7.3 Rate and Error Controls

7.3.1 Adaptive throttling

Connector workers honor Retry-After, use exponential backoff with jitter and enforce workspace quotas. Fair scheduling prevents a large tenant from starving smaller workspaces.

At the interface boundary, Connector records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/connectors/{connectorId}/sync must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event ConnectorSyncStarted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

7.3.2 Poison record handling

After bounded retries, malformed documents enter a quarantined state with a reason code, correlation ID and remediation path. The remaining sync batch may proceed while the cursor ledger records the exception.

At the interface boundary, SyncRun records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/connectors/{connectorId}/runs must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event ConnectorSyncStarted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

7.4 Component and Contract Register

The following bounded-context register identifies implementation ownership and the minimum verification surface for this chapter. It is intentionally specific enough to support a backlog of interface-level tests.

Component / interface	Contract role	Required invariant
Connector	Owner aggregate	UUIDv7 + tenant scope
SyncRun	Immutable derivative	SHA-256 source/ revision
SourceCursor	Policy-bound control	Actor and role predicate
SourceDocument	Operational ledger	Event ID + trace context
API surface	POST /v1/connectors/{connectorId}/sync	OAuth audience + idempotency policy
Secondary API	GET /v1/connectors/{connectorId}/runs	Schema contract / bounded errors
Published event	ConnectorSyncStarted	Versioned envelope / outbox

7.5 Failure Modes and Acceptance Evidence

Failure scenario A: a duplicate ConnectorSyncStarted arrives after a network retry. The consumer checks its event ledger and aggregate revision, records a duplicate outcome, and returns without reapplying the mutation. Failure scenario B: a caller changes tenant or document permissions between search and publication; the publish gate recomputes its authorization and rejects stale evidence.

Acceptance evidence: one audit record for the accepted state transition, stable error codes for denied operations, tenant-scoped traces, and an implementation test proving this chapter invariant: Revoked source access must become effective before the next retrieval.

08 Document Extraction and Normalization

The ingestion pipeline converts allowed files into immutable text, layout and metadata derivatives while preserving evidence back to source pages.

NORMATIVE INVARIANT Generated citations must resolve to stored source anchors.

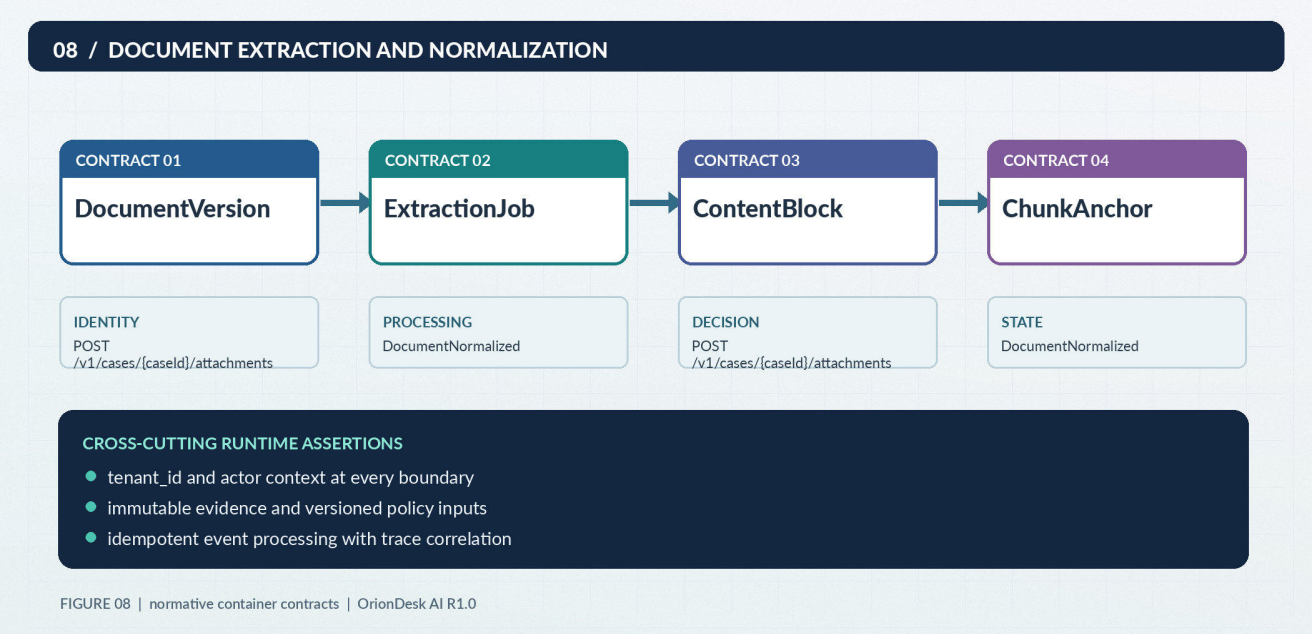


Figure 8.1 - logical components, boundary contracts and control assertions for document extraction and normalization.

8.1 Input Validation

8.1.1 Type detection and limits

MIME signature and extension must agree for accepted files. R1 supports PDF, DOCX, HTML and UTF-8 text, with a configurable 25 MB per-file cap and a decompression-bomb threshold.

At the interface boundary, DocumentVersion records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/cases/{caseId}/attachments must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event DocumentNormalized must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

8.1.2 Malware and active content

Uploads are scanned before parsing, macro execution is disabled, and embedded remote references are not fetched. Unsafe attachments are quarantined without entering the search index.

At the interface boundary, ExtractionJob records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/documents/{documentId}/status must

validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event DocumentNormalized must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

8.2 Extraction Pipeline

8.2.1 Layout-aware segmentation

PDF pages are parsed into blocks with page index and bounding boxes. Tables retain row/column annotations; headings and reading order inform chunk boundaries. OCR fallback is opt-in and provenance-marked.

At the interface boundary, ContentBlock records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/cases/{caseId}/attachments must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event DocumentNormalized must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

8.2.2 Normalization versioning

Normalization strips transport artifacts but does not rewrite claims. A content fingerprint plus pipeline version produces immutable derivative IDs; changes can be reprocessed side by side.

At the interface boundary, ChunkAnchor records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/documents/{documentId}/status must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event DocumentNormalized must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

Design checkpoint 8.2: stateful components must reject stale or unauthorized writes before publishing DocumentNormalized; integration tests assert that rejected actions leave business state unchanged.

8.3 Provenance and Quality

8.3.1 Source anchors

Every chunk stores source URI, file hash, page number and optional bounding box. The generation layer may cite only chunks with resolvable anchors and current access permission.

At the interface boundary, DocumentVersion records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/cases/{caseId}/attachments must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event DocumentNormalized must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

8.3.2 Quality gates

Extraction quality flags include empty-page ratio, unknown-character ratio, table-loss indicators and language confidence. Low-quality documents remain viewable but are excluded from autonomous recommendations.

At the interface boundary, ExtractionJob records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/documents/{documentId}/status must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event DocumentNormalized must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

8.4 Component and Contract Register

The following bounded-context register identifies implementation ownership and the minimum verification surface for this chapter. It is intentionally specific enough to support a backlog of interface-level tests.

Component / interface	Contract role	Required invariant
DocumentVersion	Owner aggregate	UUIDv7 + tenant scope
ExtractionJob	Immutable derivative	SHA-256 source/ revision
ContentBlock	Policy-bound control	Actor and role predicate
ChunkAnchor	Operational ledger	Event ID + trace context
API surface	POST /v1/cases/{caseId}/attachments	OAuth audience + idempotency policy
Secondary API	GET /v1/documents/{documentId}/status	Schema contract / bounded errors
Published event	DocumentNormalized	Versioned envelope / outbox

8.5 Failure Modes and Acceptance Evidence

Failure scenario A: a duplicate DocumentNormalized arrives after a network retry. The consumer checks its event ledger and aggregate revision, records a duplicate outcome, and returns without reapplying the mutation. Failure scenario B: a caller changes tenant or document permissions between search and publication; the publish gate recomputes its authorization and rejects stale evidence.

Acceptance evidence: one audit record for the accepted state transition, stable error codes for denied operations, tenant-scoped traces, and an implementation test proving this chapter invariant: Generated citations must resolve to stored source anchors.

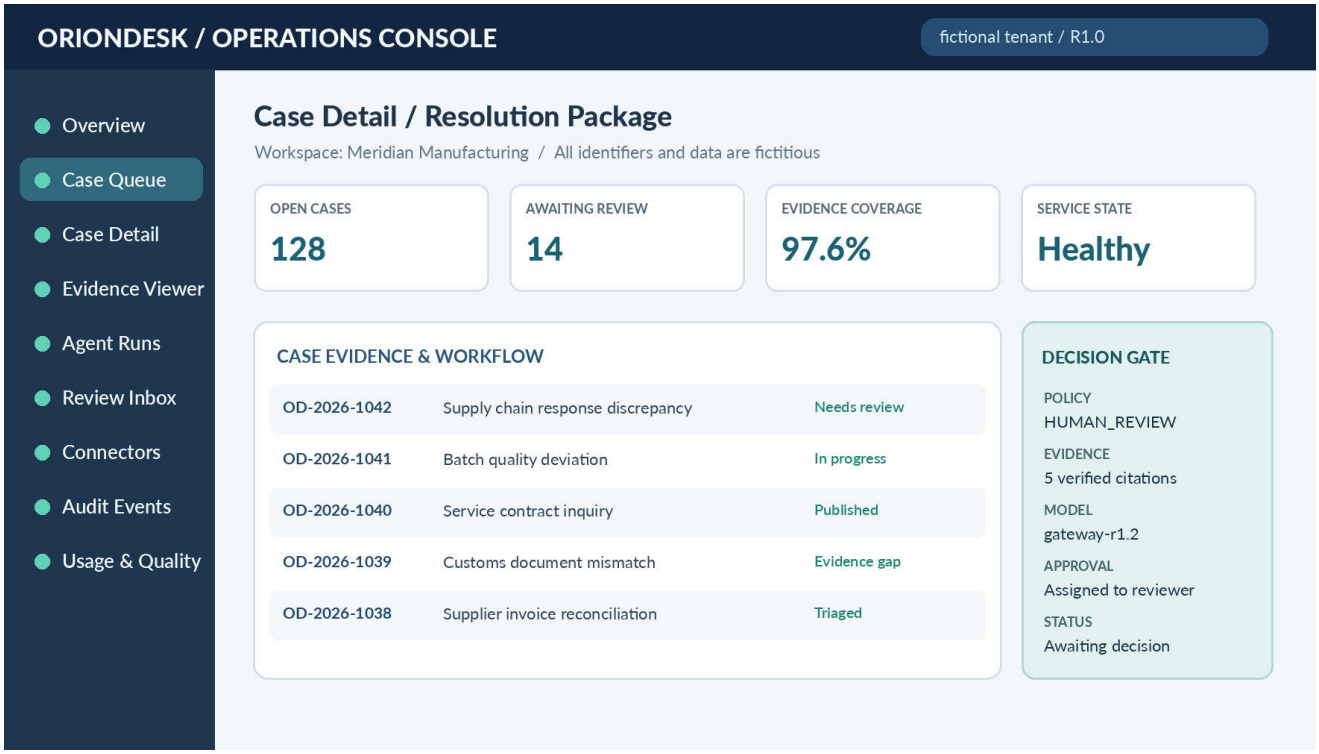


Figure 8.2 - representative operator view for the controlled scenario described in Chapter 8.

09 Search Index and Grounded Retrieval

Retrieval combines keyword ranking, semantic similarity, access-aware filters and evidence selection; ranking is separate from authorization.

NORMATIVE INVARIANT ACL filtering is applied before text is released to generation.

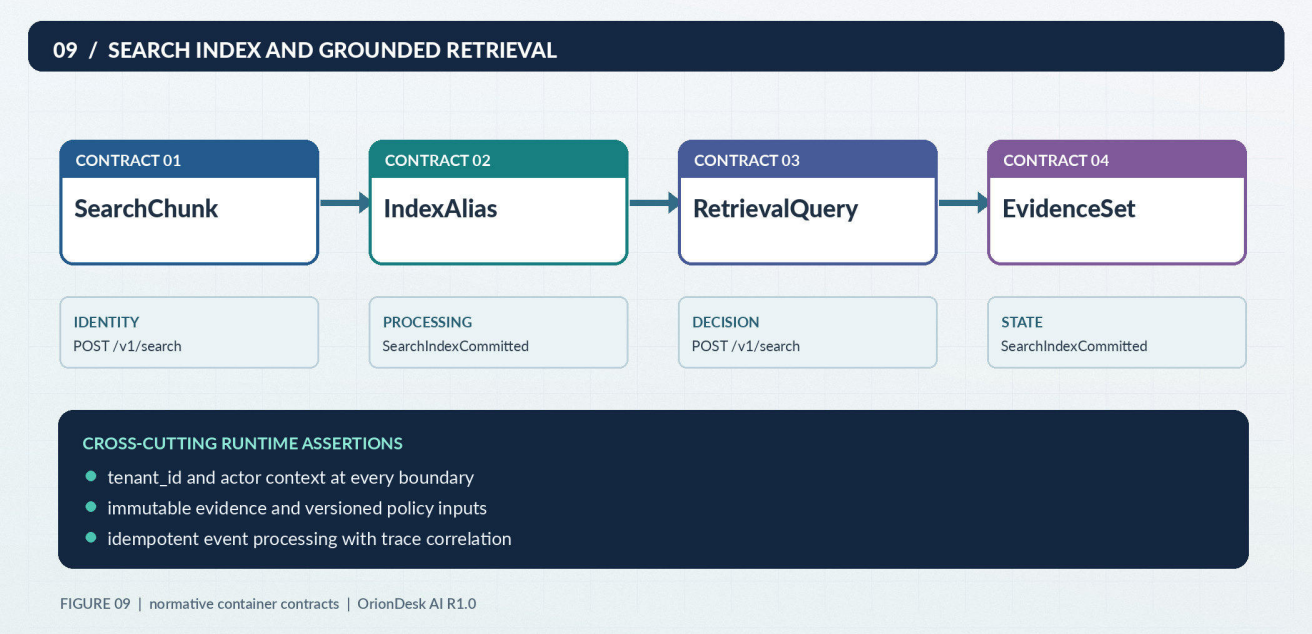


Figure 9.1 - logical components, boundary contracts and control assertions for search index and grounded retrieval.

9.1 Index Schema

9.1.1 Chunk representation

A search row stores tenant_id, workspace_id, document_version_id, chunk_id, language, classification, 1536-dimensional embedding and a text field with normalized keyword analyzers.

At the interface boundary, SearchChunk records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/search must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event SearchIndexCommitted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

9.1.2 Index lifecycle

Index writes use versioned aliases. A rebuild creates a parallel index and atomically switches the read alias after completeness and recall checks; the source database remains authoritative.

At the interface boundary, IndexAlias records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/evidence/{evidenceId} must validate input

before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event SearchIndexCommitted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

9.2 Query Processing

9.2.1 Hybrid candidates

The service forms a lexical query and a normalized vector query, retrieves bounded candidate sets, merges with reciprocal rank fusion and applies deterministic re-ranking.

At the interface boundary, RetrievalQuery records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/search must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event SearchIndexCommitted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

9.2.2 Evidence diversity

A diversity pass limits redundant hits from the same document and reserves coverage across relevant sources. Per-query budgets cap the number of tokens returned to the model.

At the interface boundary, EvidenceSet records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/evidence/{evidenceId} must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event SearchIndexCommitted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

Design checkpoint 9.2: stateful components must reject stale or unauthorized writes before publishing SearchIndexCommitted; integration tests assert that rejected actions leave business state unchanged.

9.3 Grounding Guarantees

9.3.1 Citation contract

Each response evidence item includes chunk ID, source title, document revision, page anchor and ACL digest. Citation identifiers are opaque to end users and are verified before display.

At the interface boundary, SearchChunk records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/search must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event SearchIndexCommitted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

9.3.2 Empty and ambiguous results

When confidence or evidence quality is insufficient, retrieval returns NO_SUPPORTED_EVIDENCE rather than fabricated context. The orchestrator may ask for clarification or route the case to a human.

At the interface boundary, IndexAlias records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/evidence/{evidenceId} must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event SearchIndexCommitted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

9.4 Component and Contract Register

The following bounded-context register identifies implementation ownership and the minimum verification surface for this chapter. It is intentionally specific enough to support a backlog of interface-level tests.

Component / interface	Contract role	Required invariant
SearchChunk	Owner aggregate	UUIDv7 + tenant scope
IndexAlias	Immutable derivative	SHA-256 source/ revision
RetrievalQuery	Policy-bound control	Actor and role predicate
EvidenceSet	Operational ledger	Event ID + trace context
API surface	POST /v1/search	OAuth audience + idempotency policy
Secondary API	GET /v1/evidence/{evidenceId}	Schema contract / bounded errors
Published event	SearchIndexCommitted	Versioned envelope / outbox

9.5 Failure Modes and Acceptance Evidence

Failure scenario A: a duplicate SearchIndexCommitted arrives after a network retry. The consumer checks its event ledger and aggregate revision, records a duplicate outcome, and returns without reapplying the mutation. Failure scenario B: a caller changes tenant or document permissions between search and publication; the publish gate recomputes its authorization and rejects stale evidence.

Acceptance evidence: one audit record for the accepted state transition, stable error codes for denied operations, tenant-scoped traces, and an implementation test proving this chapter invariant: ACL filtering is applied before text is released to generation.

10 Model Gateway and Prompt Lifecycle

The model gateway isolates provider details, token budgets, model policies, structured-output validation, safety instrumentation and cost accounting.

NORMATIVE INVARIANT Model output is data, never proof that a tool action is authorized.

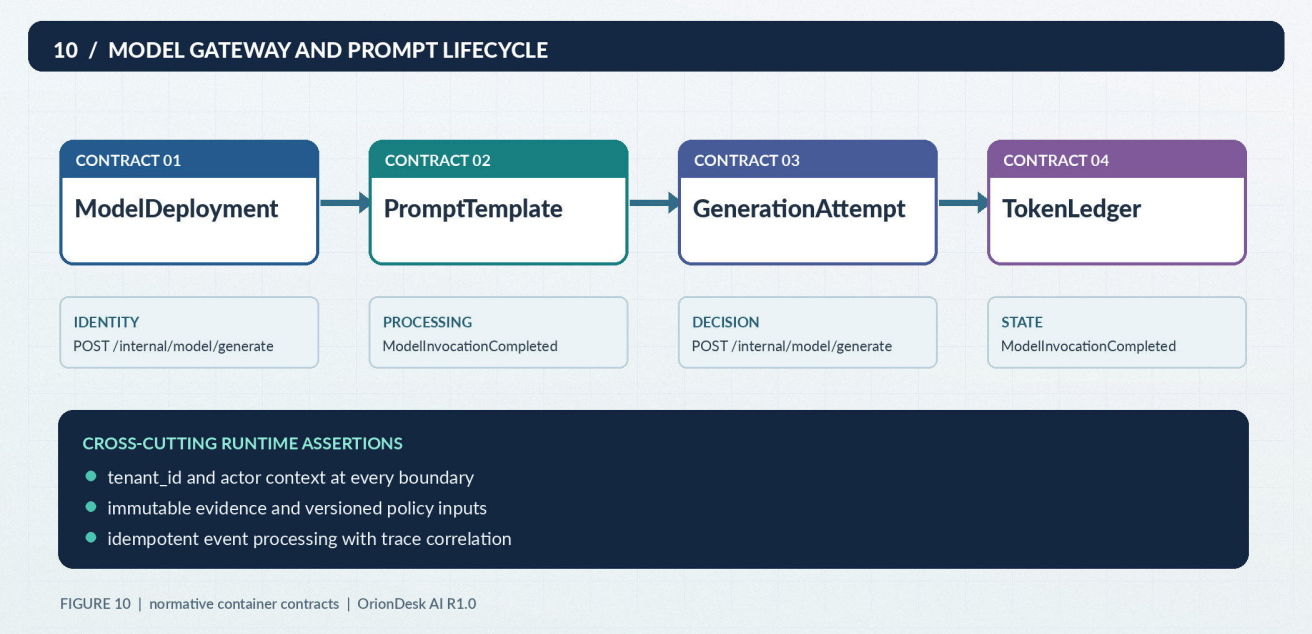


Figure 10.1 - logical components, boundary contracts and control assertions for model gateway and prompt lifecycle.

10.1 Model Routing

10.1.1 Registry and selection

Models are registered by capability, region, data-handling class, context length, cost profile and evaluation approval. A workspace policy whitelists specific deployments rather than broad provider brands.

At the interface boundary, ModelDeployment records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /internal/model/generate must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event ModelInvocationCompleted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

10.1.2 Fallback constraints

Fallback is allowed only to an approved model of equal or stronger data-handling class. A provider outage must not route restricted content to an unapproved region or deployment.

At the interface boundary, PromptTemplate records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/model-catalog must validate

input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event ModelInvocationCompleted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

10.2 Prompt Construction

10.2.1 Template composition

A prompt includes fixed system rules, a signed workflow instruction, validated user input and separately delimited retrieved passages. Source text is never promoted into instruction authority.

At the interface boundary, GenerationAttempt records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /internal/model/generate must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event ModelInvocationCompleted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

10.2.2 Structured-output validation

The gateway requests a versioned JSON schema and parses the result with bounded retries. Unknown fields, invalid citations and control-character injection trigger MODEL_OUTPUT_INVALID.

At the interface boundary, TokenLedger records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/model-catalog must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event ModelInvocationCompleted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

Design checkpoint 10.2: stateful components must reject stale or unauthorized writes before publishing ModelInvocationCompleted; integration tests assert that rejected actions leave business state unchanged.

10.3 Budget and Safety

10.3.1 Token and cost accounting

Each run reserves an input/output token budget and tracks provider usage under a workspace quota. Quota exhaustion is terminal for the current run without automatically changing model or data class.

At the interface boundary, ModelDeployment records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /internal/model/generate must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event ModelInvocationCompleted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

10.3.2 Adversarial prompt handling

Retrieved content is labeled untrusted. The gateway strips tool-call directives from evidence contexts, records prompt-injection indicators and requires tool authorization outside model text.

At the interface boundary, PromptTemplate records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/model-catalog must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event ModelInvocationCompleted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

10.4 Component and Contract Register

The following bounded-context register identifies implementation ownership and the minimum verification surface for this chapter. It is intentionally specific enough to support a backlog of interface-level tests.

Component / interface	Contract role	Required invariant
ModelDeployment	Owner aggregate	UUIDv7 + tenant scope
PromptTemplate	Immutable derivative	SHA-256 source/ revision
GenerationAttempt	Policy-bound control	Actor and role predicate
TokenLedger	Operational ledger	Event ID + trace context
API surface	POST /internal/model/generate	OAuth audience + idempotency policy
Secondary API	GET /v1/model-catalog	Schema contract / bounded errors
Published event	ModelInvocationCompleted	Versioned envelope / outbox

10.5 Failure Modes and Acceptance Evidence

Failure scenario A: a duplicate ModelInvocationCompleted arrives after a network retry. The consumer checks its event ledger and aggregate revision, records a duplicate outcome, and returns without reapplying the mutation. Failure scenario B: a caller changes tenant or document permissions between search and publication; the publish gate recomputes its authorization and rejects stale evidence.

Acceptance evidence: one audit record for the accepted state transition, stable error codes for denied operations, tenant-scoped traces, and an implementation test proving this chapter invariant: Model output is data, never proof that a tool action is authorized.

11 Agent Orchestration and Tool Access

A bounded planner coordinates specialized agents and narrow tools while maintaining human-visible execution traces and deterministic policy checkpoints.

NORMATIVE INVARIANT Agent discovery must never grant action permission.

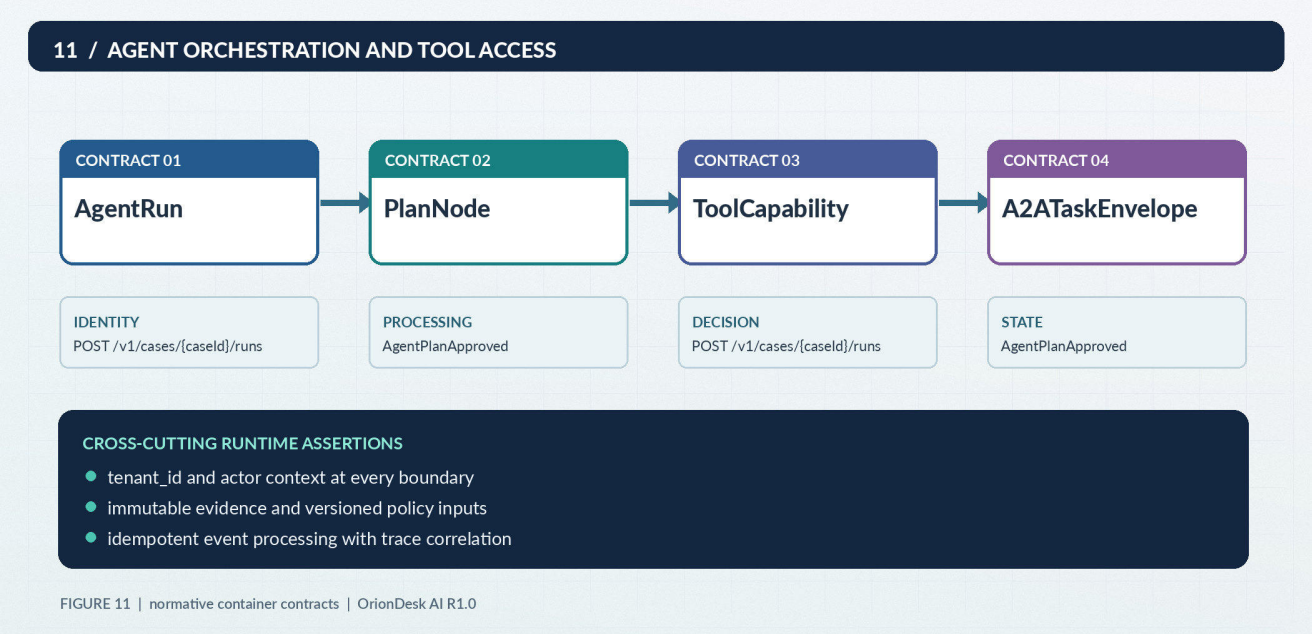


Figure 11.1 - logical components, boundary contracts and control assertions for agent orchestration and tool access.

11.1 Plan and Run State

11.1.1 Agent responsibilities

The Triage Agent classifies the case, the Research Agent requests grounded evidence, and the Draft Agent assembles a candidate response. The Policy Evaluator is deterministic and is not an LLM agent.

At the interface boundary, AgentRun records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/cases/{caseId}/runs must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event AgentPlanApproved must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

11.1.2 Run DAG and checkpoints

The run plan is a directed acyclic graph with bounded depth eight, maximum sixteen tool invocations, explicit dependencies and re-playable checkpoints. A run stores the plan revision before executing side effects.

At the interface boundary, PlanNode records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/runs/{runId}/steps must validate input before

allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event AgentPlanApproved must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

11.2 MCP and A2A Boundaries

11.2.1 MCP tool servers

Approved MCP servers expose typed retrieval and business functions through scoped service credentials. Tool schemas are pinned by version; arguments are validated and all external writes require separate capability authorization.

At the interface boundary, ToolCapability records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/cases/{caseId}/runs must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event AgentPlanApproved must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

11.2.2 Agent-to-agent handoff

A2A messages carry a task ID, capability reference, declared input/output schema, deadline and trace context. The receiving agent may decline; discovery does not imply permission to invoke a capability.

At the interface boundary, A2ATaskEnvelope records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/runs/{runId}/steps must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event AgentPlanApproved must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

Design checkpoint 11.2: stateful components must reject stale or unauthorized writes before publishing AgentPlanApproved; integration tests assert that rejected actions leave business state unchanged.

11.3 Control and Failure Policy

11.3.1 Stop conditions

The orchestrator terminates on missing approval, exhausted call budget, repeated invalid plans, policy denial or deadline expiry. The visible run status reports exactly which checkpoint failed.

At the interface boundary, AgentRun records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/cases/{caseId}/runs must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event AgentPlanApproved must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

11.3.2 Side-effect safety

Read operations can retry after transient faults; mutable operations require idempotency keys and human authorization if consequential. The planner cannot replace a denied action with a semantically equivalent tool.

At the interface boundary, PlanNode records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/runs/{runId}/steps must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event AgentPlanApproved must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

11.4 Component and Contract Register

The following bounded-context register identifies implementation ownership and the minimum verification surface for this chapter. It is intentionally specific enough to support a backlog of interface-level tests.

Component / interface	Contract role	Required invariant
AgentRun	Owner aggregate	UUIDv7 + tenant scope
PlanNode	Immutable derivative	SHA-256 source/ revision
ToolCapability	Policy-bound control	Actor and role predicate
A2ATaskEnvelope	Operational ledger	Event ID + trace context
API surface	POST /v1/cases/{caseId}/runs	OAuth audience + idempotency policy
Secondary API	GET /v1/runs/{runId}/steps	Schema contract / bounded errors
Published event	AgentPlanApproved	Versioned envelope / outbox

11.5 Failure Modes and Acceptance Evidence

Failure scenario A: a duplicate AgentPlanApproved arrives after a network retry. The consumer checks its event ledger and aggregate revision, records a duplicate outcome, and returns without reapplying the mutation. Failure scenario B: a caller changes tenant or document permissions between search and publication; the publish gate recomputes its authorization and rejects stale evidence.

Acceptance evidence: one audit record for the accepted state transition, stable error codes for denied operations, tenant-scoped traces, and an implementation test proving this chapter invariant: Agent discovery must never grant action permission.

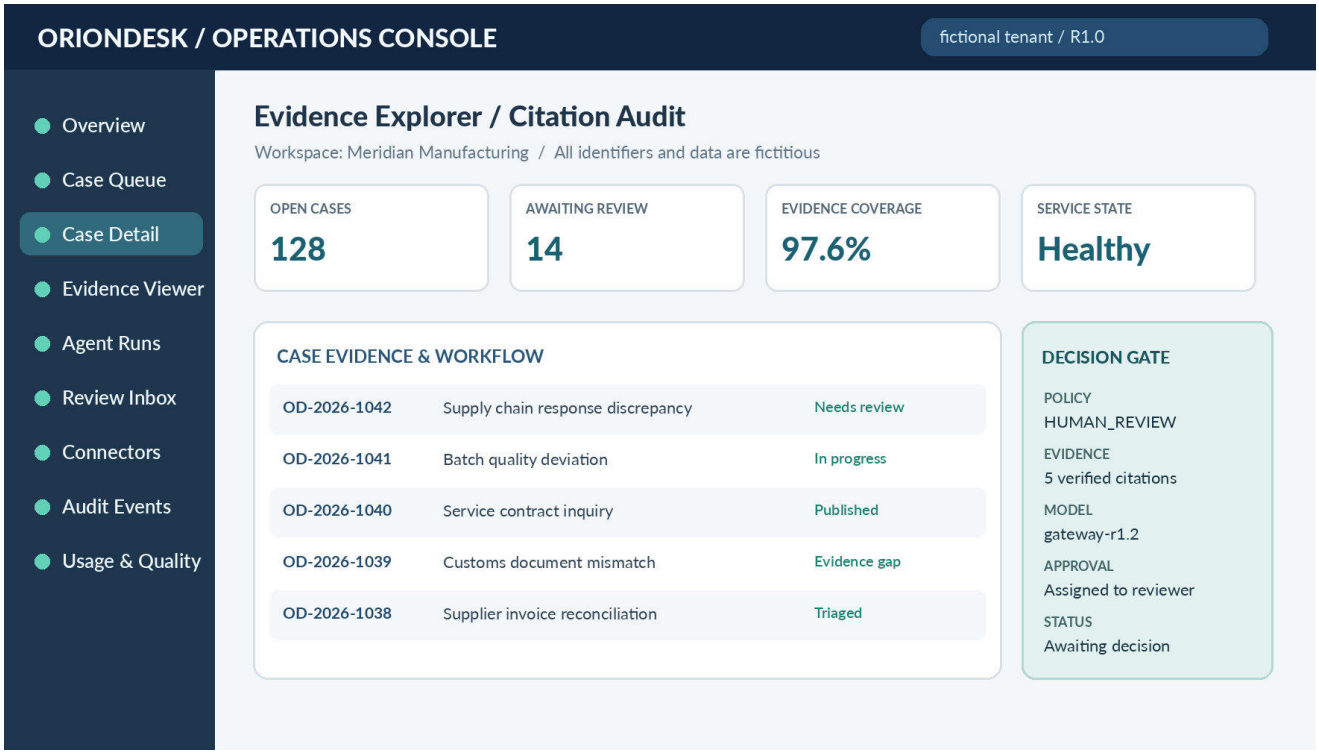


Figure 11.2 - representative operator view for the controlled scenario described in Chapter 11.

12 Policy Decisions and Human Approval

Risk classification uses reproducible policy inputs; high-impact recommendations become review tasks rather than autonomous mutations.

NORMATIVE INVARIANT An approval applies only to the exact content hash reviewed.

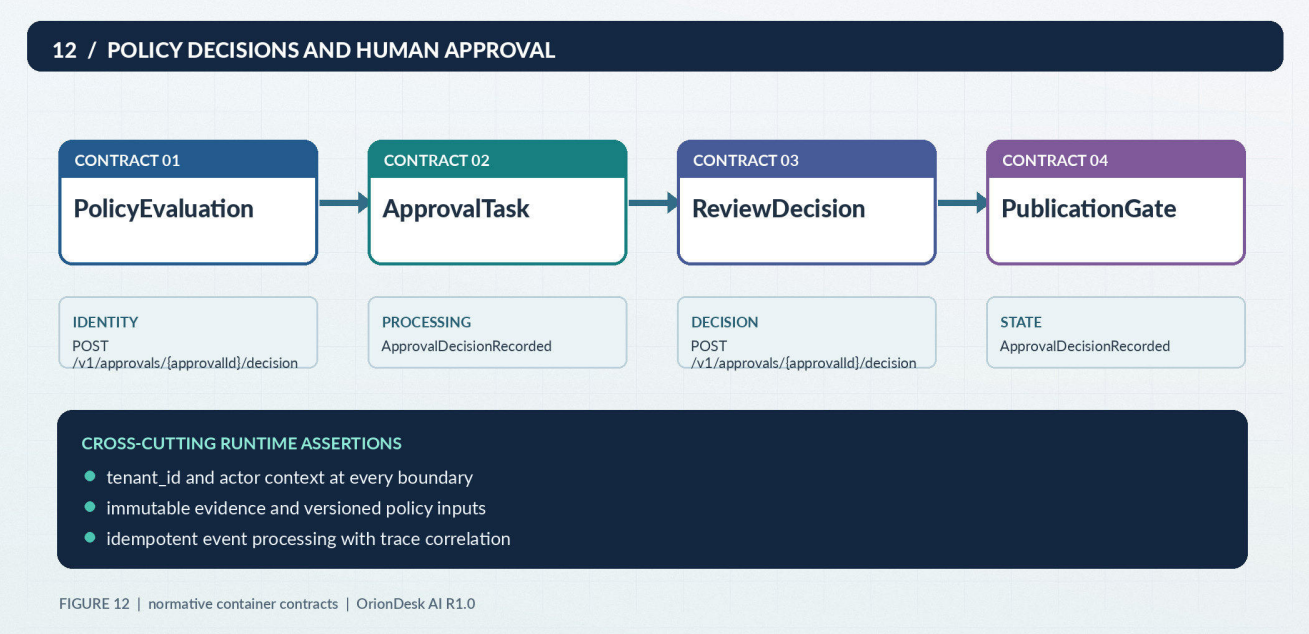


Figure 12.1 - logical components, boundary contracts and control assertions for policy decisions and human approval.

12.1 Deterministic Decision Rules

12.1.1 Rule inputs

Policy evaluates case sensitivity, requested action, evidence quality, model class, financial impact category and confidence bands. All inputs are normalized and stored with rule-set version.

At the interface boundary, PolicyEvaluation records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/approvals/{approvalId}/decision must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event ApprovalDecisionRecorded must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

12.1.2 Outcome vocabulary

The engine returns AUTO_ALLOW, HUMAN_REVIEW, REQUEST_MORE_EVIDENCE or DENY. An LLM may propose risk tags but never override policy outcomes.

At the interface boundary, ApprovalTask records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/review-queue must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event ApprovalDecisionRecorded must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

12.2 Review Queue

12.2.1 Assignment and expiry

Review tasks use policy-defined reviewer pools, minimum role and separation-of-duty constraints. Tasks expire after a configured SLA and are reassigned or escalated without silently approving.

At the interface boundary, ReviewDecision records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/approvals/{approvalId}/decision must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event ApprovalDecisionRecorded must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

12.2.2 Decision capture

Approval records include decision, actor, timestamp, evaluated artifact hash, rationale and optional annotations. A decision on a changed artifact is rejected as stale.

At the interface boundary, PublicationGate records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/review-queue must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event ApprovalDecisionRecorded must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

Design checkpoint 12.2: stateful components must reject stale or unauthorized writes before publishing ApprovalDecisionRecorded; integration tests assert that rejected actions leave business state unchanged.

12.3 Publication Gate

12.3.1 Atomic publication

The final response pointer updates in the same transaction that records the satisfied approval gate. A queue replay cannot publish a different artifact under an old approval.

At the interface boundary, PolicyEvaluation records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/approvals/{approvalId}/decision must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event ApprovalDecisionRecorded must be visible through correlated logs and the audit record without

placing source document text in diagnostic telemetry.

12.3.2 Appeal and overrides

An authorized override requires elevated role, secondary reviewer and audited reason. Denied requests can be reworked as new run revisions, not retroactively marked approved.

At the interface boundary, ApprovalTask records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/review-queue must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event ApprovalDecisionRecorded must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

12.4 Component and Contract Register

The following bounded-context register identifies implementation ownership and the minimum verification surface for this chapter. It is intentionally specific enough to support a backlog of interface-level tests.

Component / interface	Contract role	Required invariant
PolicyEvaluation	Owner aggregate	UUIDv7 + tenant scope
ApprovalTask	Immutable derivative	SHA-256 source/ revision
ReviewDecision	Policy-bound control	Actor and role predicate
PublicationGate	Operational ledger	Event ID + trace context
API surface	POST /v1/approvals/{approvalId}/decision	OAuth audience + idempotency policy
Secondary API	GET /v1/review-queue	Schema contract / bounded errors
Published event	ApprovalDecisionRecorded	Versioned envelope / outbox

12.5 Failure Modes and Acceptance Evidence

Failure scenario A: a duplicate ApprovalDecisionRecorded arrives after a network retry. The consumer checks its event ledger and aggregate revision, records a duplicate outcome, and returns without reapplying the mutation. Failure scenario B: a caller changes tenant or document permissions between search and publication; the publish gate recomputes its authorization and rejects stale evidence.

Acceptance evidence: one audit record for the accepted state transition, stable error codes for denied operations, tenant-scoped traces, and an implementation test proving this chapter invariant: An approval applies only to the exact content hash reviewed.

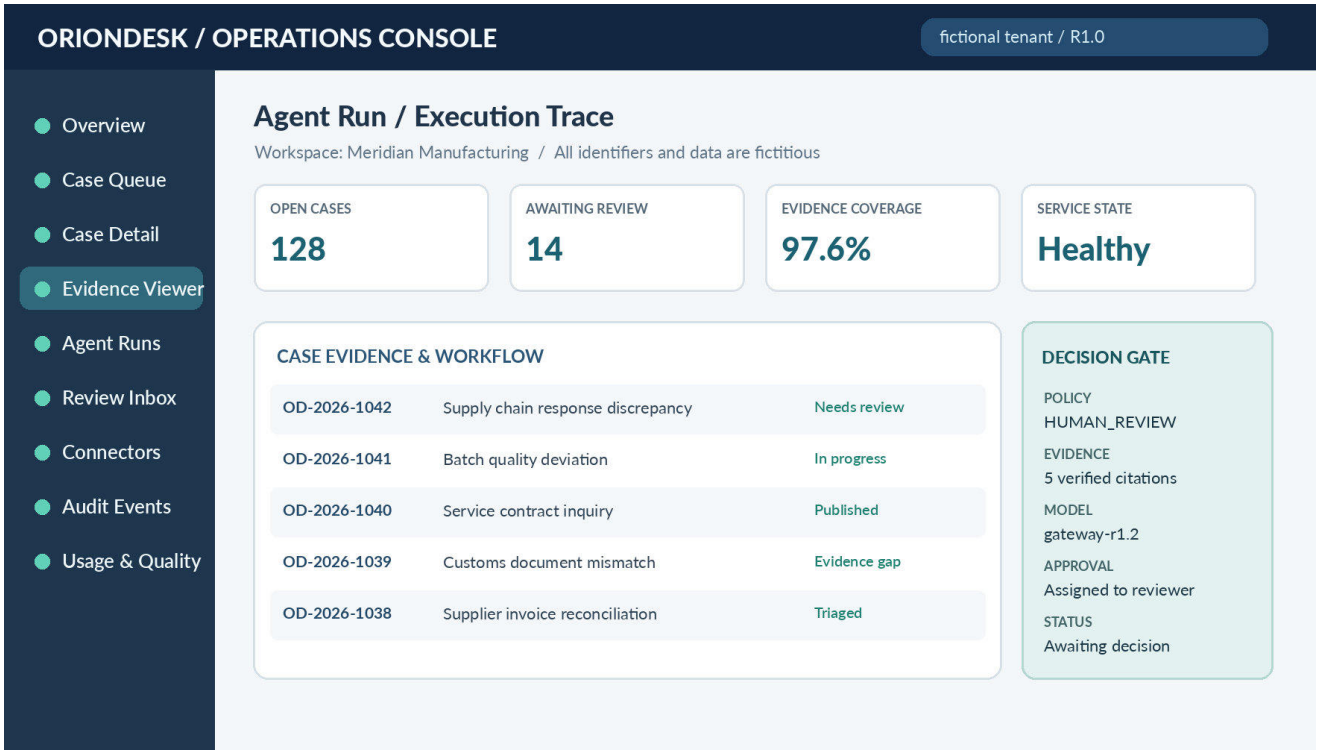


Figure 12.2 - representative operator view for the controlled scenario described in Chapter 12.

13 Workflow, Queues and Event Semantics

Long-running extraction, indexing and AI runs use durable orchestration, outbox events, bounded retries and dead-letter recovery.

NORMATIVE INVARIANT Consumers must be safe under duplicate and delayed delivery.

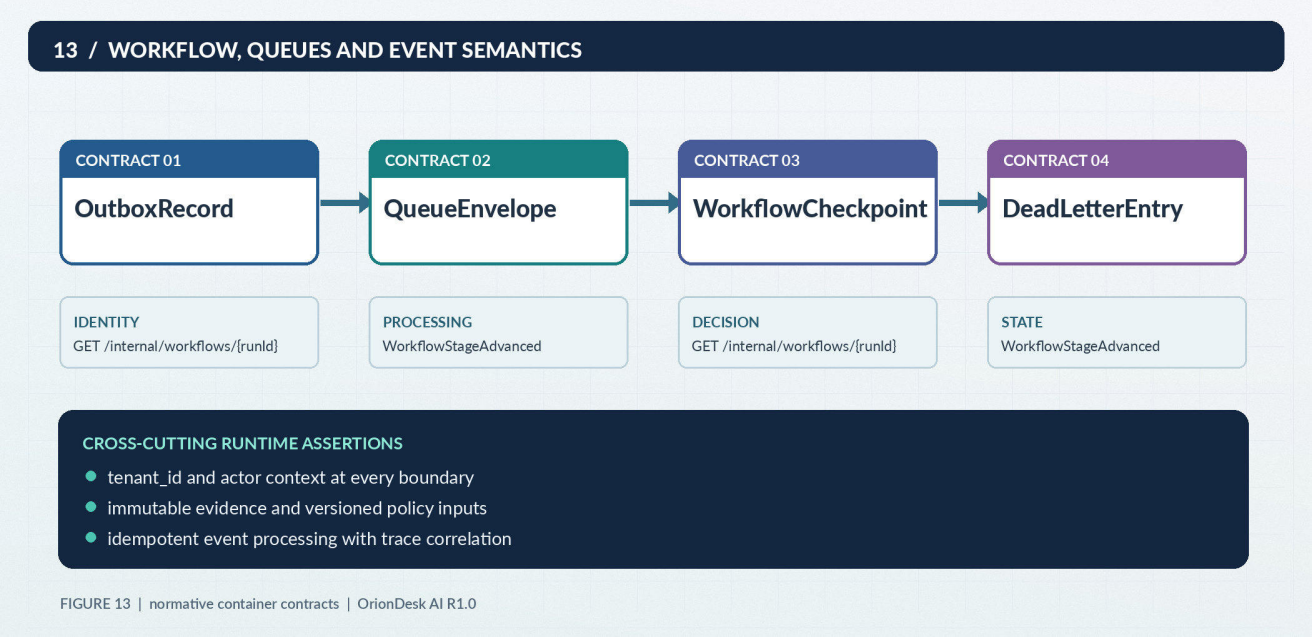


Figure 13.1 - logical components, boundary contracts and control assertions for workflow, queues and event semantics.

13.1 Messaging Contracts

13.1.1 Event envelope

All events contain event_id, type, schema_version, tenant_id, aggregate_id, aggregate_revision, occurred_at, trace_id and payload. Producers use UTC and canonical JSON.

At the interface boundary, OutboxRecord records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /internal/workflows/{runId} must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event WorkflowStageAdvanced must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

13.1.2 Delivery semantics

At-least-once delivery is assumed; consumers deduplicate event IDs and detect stale aggregate revisions. No business invariant relies on queue ordering across different partitions.

At the interface boundary, QueueEnvelope records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /internal/deadletters/{id}/replay

must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event WorkflowStageAdvanced must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

13.2 Saga Coordination

13.2.1 Workflow stages

A run moves REQUESTED -> RETRIEVING -> GENERATING -> POLICY_CHECK -> AWAITING_REVIEW -> PUBLISHED or a terminal failure state. Each stage writes a checkpoint before downstream dispatch.

At the interface boundary, WorkflowCheckpoint records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /internal/workflows/{runId} must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event WorkflowStageAdvanced must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

13.2.2 Compensation and reconciliation

A failed index write does not rollback accepted source metadata; a reconciliation worker compares fingerprints and retries. Broken message links are repaired from the outbox ledger.

At the interface boundary, DeadLetterEntry records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /internal/deadletters/{id}/replay must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event WorkflowStageAdvanced must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

Design checkpoint 13.2: stateful components must reject stale or unauthorized writes before publishing WorkflowStageAdvanced; integration tests assert that rejected actions leave business state unchanged.

13.3 Retry and Dead Letters

13.3.1 Backoff discipline

Transient failures use bounded exponential backoff, randomized jitter and per-dependency circuit breakers. Validation and permission failures are permanent and not retried.

At the interface boundary, OutboxRecord records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /internal/workflows/{runId} must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event WorkflowStageAdvanced must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

13.3.2 Operator replay

Dead-letter replay requires an operator reason, dry-run validation and scope limit. The replay preserves original event identity unless migration transforms the schema with an explicit provenance link.

At the interface boundary, QueueEnvelope records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /internal/deadletters/{id}/replay must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event WorkflowStageAdvanced must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

13.4 Component and Contract Register

The following bounded-context register identifies implementation ownership and the minimum verification surface for this chapter. It is intentionally specific enough to support a backlog of interface-level tests.

Component / interface	Contract role	Required invariant
OutboxRecord	Owner aggregate	UUIDv7 + tenant scope
QueueEnvelope	Immutable derivative	SHA-256 source/ revision
WorkflowCheckpoint	Policy-bound control	Actor and role predicate
DeadLetterEntry	Operational ledger	Event ID + trace context
API surface	GET /internal/workflows/{runId}	OAuth audience + idempotency policy
Secondary API	POST /internal/deadletters/{id}/replay	Schema contract / bounded errors
Published event	WorkflowStageAdvanced	Versioned envelope / outbox

13.5 Failure Modes and Acceptance Evidence

Failure scenario A: a duplicate WorkflowStageAdvanced arrives after a network retry. The consumer checks its event ledger and aggregate revision, records a duplicate outcome, and returns without reapplying the mutation. Failure scenario B: a caller changes tenant or document permissions between search and publication; the publish gate recomputes its authorization and rejects stale evidence.

Acceptance evidence: one audit record for the accepted state transition, stable error codes for denied operations, tenant-scoped traces, and an implementation test proving this chapter invariant: Consumers must be safe under duplicate and delayed delivery.

14 Relational Data and Object Storage Design

Persistent data contracts enforce tenancy, revision safety, referential integrity and deletion semantics independent of AI behavior.

NORMATIVE INVARIANT Tenant identity is part of every storage access predicate.

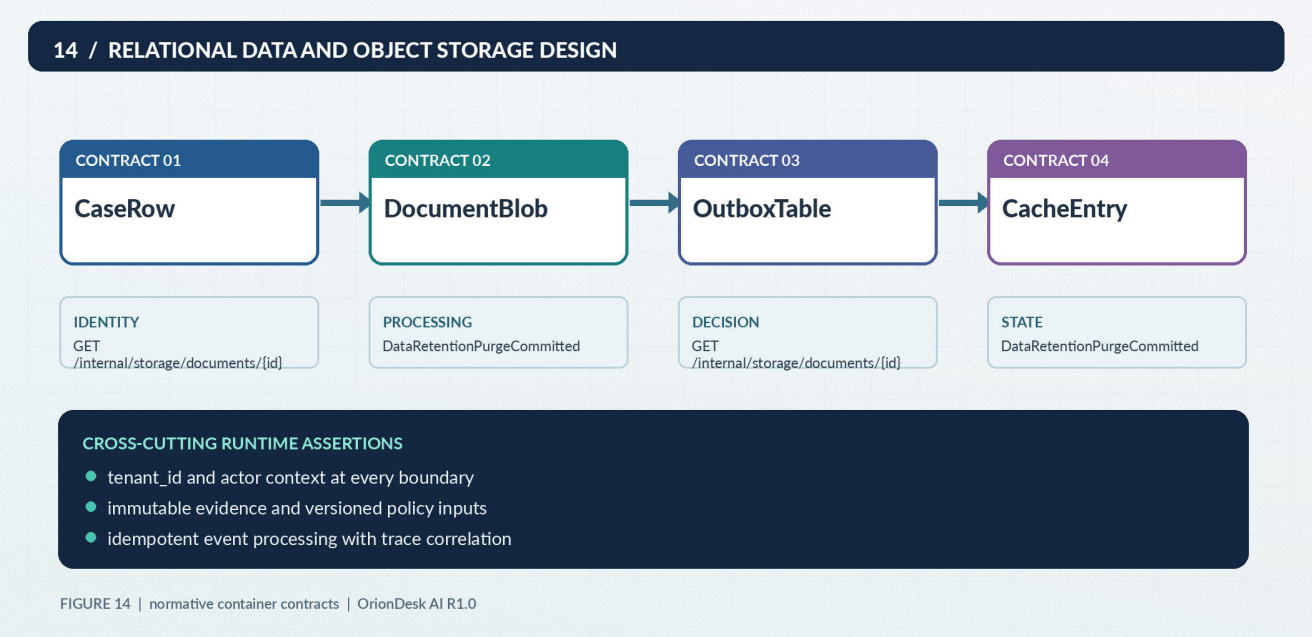


Figure 14.1 - logical components, boundary contracts and control assertions for relational data and object storage design.

14.1 Schema and Constraints

14.1.1 Primary keys and identity

Identifiers are UUIDv7 for sortable event-time locality, while tenant_id is a mandatory partitioning and security attribute. Unique constraints are scoped to tenant and business key.

At the interface boundary, CaseRow records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /internal/storage/documents/{id} must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event DataRetentionPurgeCommitted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

14.1.2 Foreign keys and soft deletion

Case attachments reference immutable document versions; approvals reference run artifact hashes. Soft-deleted entities cannot be retrieved, and final purge uses a scheduled tombstone pipeline.

At the interface boundary, DocumentBlob records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /internal/storage/purge must validate input

before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event DataRetentionPurgeCommitted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

14.2 Transaction Strategy

14.2.1 Write boundaries

Case mutations, approval decisions and outbox inserts commit in one ACID transaction. Search indexing and external webhooks are asynchronous with explicit reconciliation.

At the interface boundary, OutboxTable records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /internal/storage/documents/{id} must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event DataRetentionPurgeCommitted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

14.2.2 Migrations and compatibility

Expand-and-contract migrations add nullable columns first, backfill in bounded batches, then enforce constraints. No deployment removes a field while active readers still depend on it.

At the interface boundary, CacheEntry records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /internal/storage/purge must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event DataRetentionPurgeCommitted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

Design checkpoint 14.2: stateful components must reject stale or unauthorized writes before publishing DataRetentionPurgeCommitted; integration tests assert that rejected actions leave business state unchanged.

14.3 Object and Cache Layout

14.3.1 Blob key design

Blob keys include tenant, workspace, document, version and object role; public names are opaque. Encryption-at-rest and access-controlled short-lived signed URLs are mandatory.

At the interface boundary, CaseRow records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /internal/storage/documents/{id} must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event DataRetentionPurgeCommitted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

14.3.2 Cache invalidation

Cache keys contain tenant, user-scope digest, source ACL revision, query hash and index generation. Authorization changes purge affected entries before normal TTL expiration.

At the interface boundary, DocumentBlob records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /internal/storage/purge must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event DataRetentionPurgeCommitted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

14.4 Component and Contract Register

The following bounded-context register identifies implementation ownership and the minimum verification surface for this chapter. It is intentionally specific enough to support a backlog of interface-level tests.

Component / interface	Contract role	Required invariant
CaseRow	Owner aggregate	UUIDv7 + tenant scope
DocumentBlob	Immutable derivative	SHA-256 source/ revision
OutboxTable	Policy-bound control	Actor and role predicate
CacheEntry	Operational ledger	Event ID + trace context
API surface	GET /internal/storage/documents/{id}	OAuth audience + idempotency policy
Secondary API	POST /internal/storage/purge	Schema contract / bounded errors
Published event	DataRetentionPurgeCommitted	Versioned envelope / outbox

14.5 Failure Modes and Acceptance Evidence

Failure scenario A: a duplicate DataRetentionPurgeCommitted arrives after a network retry. The consumer checks its event ledger and aggregate revision, records a duplicate outcome, and returns without reapplying the mutation. Failure scenario B: a caller changes tenant or document permissions between search and publication; the publish gate recomputes its authorization and rejects stale evidence.

Acceptance evidence: one audit record for the accepted state transition, stable error codes for denied operations, tenant-scoped traces, and an implementation test proving this chapter invariant: Tenant identity is part of every storage access predicate.

15 Public API and Internal RPC Contracts

REST is the external interface; internal gRPC and HTTP contracts are versioned, generated and independently authorized.

NORMATIVE INVARIANT Public response fields must never expose secret or raw provider credentials.

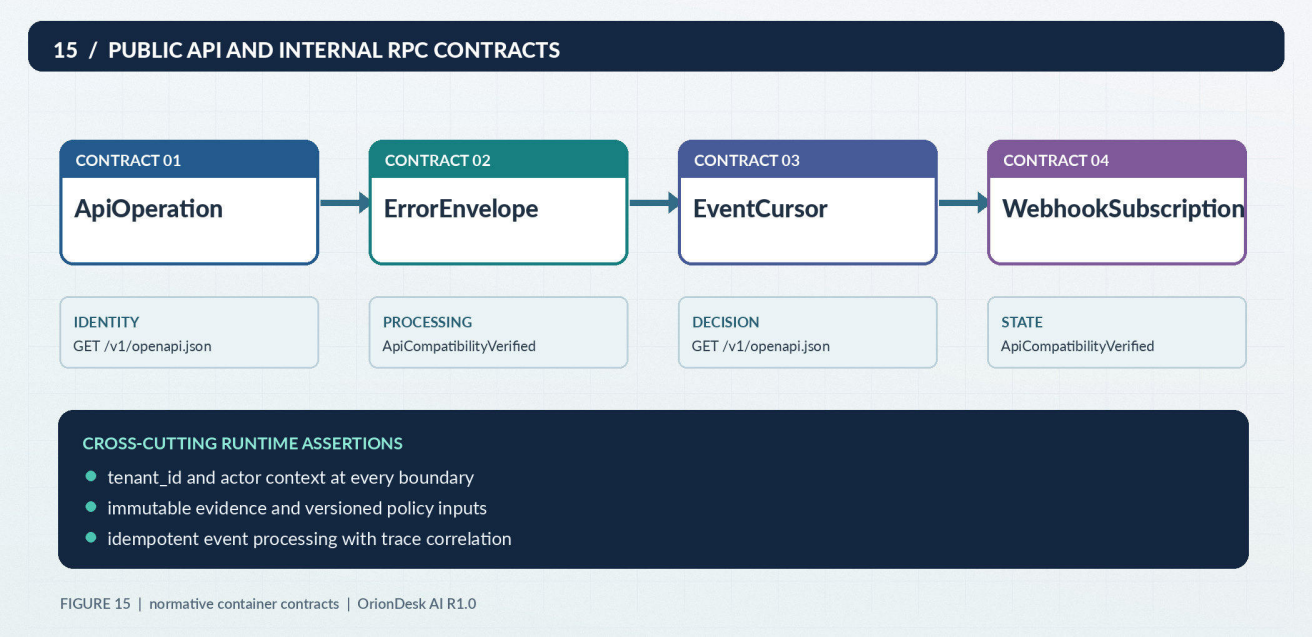


Figure 15.1 - logical components, boundary contracts and control assertions for public api and internal rpc contracts.

15.1 REST Semantics

15.1.1 Resource naming and errors

Public APIs use /v1 nouns, cursor pagination, RFC 3339 timestamps and stable snake-case error codes. HTTP 409 means revision conflict, 429 means quota, and 422 means schema-invalid request.

At the interface boundary, ApiOperation records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/openapi.json must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event ApiCompatibilityVerified must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

15.1.2 Idempotent mutations

POST mutations that create long-running jobs require Idempotency-Key. A repeated identical payload returns the original operation; the same key with a different fingerprint returns IDEMPOTENCY_CONFLICT.

At the interface boundary, ErrorEnvelope records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/streams/runs/{runId} must validate input

before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event ApiCompatibilityVerified must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

15.2 Streaming and Notifications

15.2.1 Server-sent events

Long-running run updates are served over SSE with monotonically increasing event offsets. Reconnect uses Last-Event-ID and backfills retained events without replaying private data outside the caller scope.

At the interface boundary, EventCursor records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/openapi.json must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event ApiCompatibilityVerified must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

15.2.2 Webhook contract

Optional outbound webhooks are signed and retried with exponential backoff. Recipients verify signature and event age; webhook failure cannot rollback the internal case transition.

At the interface boundary, WebhookSubscription records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/streams/runs/{runId} must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event ApiCompatibilityVerified must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

Design checkpoint 15.2: stateful components must reject stale or unauthorized writes before publishing ApiCompatibilityVerified; integration tests assert that rejected actions leave business state unchanged.

15.3 Schema Governance

15.3.1 OpenAPI and protobuf

The external OpenAPI contract is the source of truth for REST clients; protobuf IDL governs internal gRPC messages. CI prevents breaking field deletion or incompatible enum changes.

At the interface boundary, ApiOperation records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/openapi.json must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event ApiCompatibilityVerified must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

15.3.2 Validation boundaries

Payloads are validated before transaction entry, again at domain invariants and before tool dispatch. Client-side validation is convenience only and is not a security boundary.

At the interface boundary, ErrorEnvelope records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/streams/runs/{runId} must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event ApiCompatibilityVerified must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

15.4 Component and Contract Register

The following bounded-context register identifies implementation ownership and the minimum verification surface for this chapter. It is intentionally specific enough to support a backlog of interface-level tests.

Component / interface	Contract role	Required invariant
ApiOperation	Owner aggregate	UUIDv7 + tenant scope
ErrorEnvelope	Immutable derivative	SHA-256 source/ revision
EventCursor	Policy-bound control	Actor and role predicate
WebhookSubscription	Operational ledger	Event ID + trace context
API surface	GET /v1/openapi.json	OAuth audience + idempotency policy
Secondary API	GET /v1/streams/runs/{runId}	Schema contract / bounded errors
Published event	ApiCompatibilityVerified	Versioned envelope / outbox

15.5 Failure Modes and Acceptance Evidence

Failure scenario A: a duplicate ApiCompatibilityVerified arrives after a network retry. The consumer checks its event ledger and aggregate revision, records a duplicate outcome, and returns without reapplying the mutation. Failure scenario B: a caller changes tenant or document permissions between search and publication; the publish gate recomputes its authorization and rejects stale evidence.

Acceptance evidence: one audit record for the accepted state transition, stable error codes for denied operations, tenant-scoped traces, and an implementation test proving this chapter invariant: Public response fields must never expose secret or raw provider credentials.

16 User Interface, Accessibility and Interaction

The browser gives analysts a navigable case workspace, provenance-first evidence review and explicit controls for human approval.

NORMATIVE INVARIANT A reviewer must be able to inspect source evidence before approval.

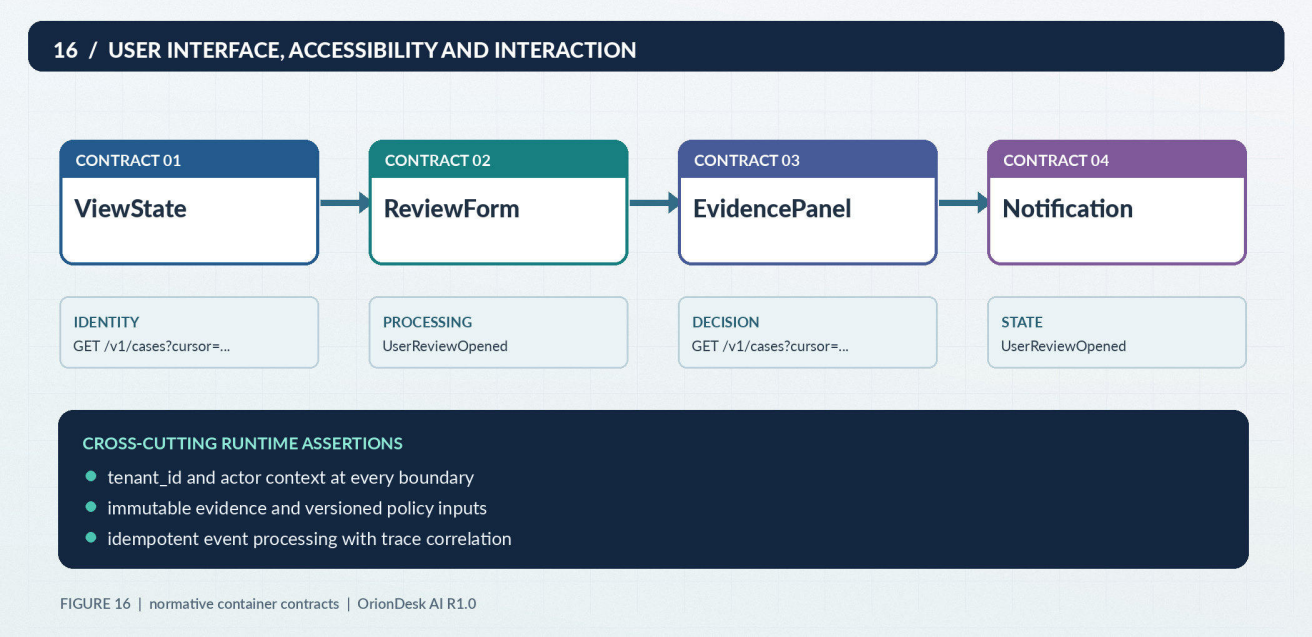


Figure 16.1 - logical components, boundary contracts and control assertions for user interface, accessibility and interaction.

16.1 Navigation and Information Design

16.1.1 Primary screens

The application contains Case Queue, Case Detail, Evidence Viewer, Run Timeline, Review Inbox, Connector Health, Policy Settings and Audit Explorer. Each screen has one primary action and a clear status summary.

At the interface boundary, ViewState records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/cases?cursor=... must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event UserReviewOpened must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

16.1.2 Status language

AI drafts are labeled DRAFT, NEEDS_REVIEW or PUBLISHED; visual styling never substitutes for accessible text. Citation click-through opens the source document and highlights the anchored page range.

At the interface boundary, ReviewForm records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/cases/{caseId}/evidence must validate input

before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event UserReviewOpened must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

16.2 Interaction Models

16.2.1 Long-running operations

A run is created immediately; the UI subscribes to SSE and shows retrieval, generation and policy stages. Refreshing the page reconstructs progress from server state rather than ephemeral browser memory.

At the interface boundary, EvidencePanel records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/cases?cursor=... must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event UserReviewOpened must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

16.2.2 Review evidence panel

Reviewers see the exact candidate artifact, source citations, model/prompt version and policy reasons. Approve and Reject controls are disabled until required review fields are complete.

At the interface boundary, Notification records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/cases/{caseId}/evidence must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event UserReviewOpened must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

Design checkpoint 16.2: stateful components must reject stale or unauthorized writes before publishing UserReviewOpened; integration tests assert that rejected actions leave business state unchanged.

16.3 Accessibility and Localization

16.3.1 Keyboard and screen reader

Controls conform to WCAG 2.2 AA target behavior, visible focus, semantic regions and robust keyboard ordering. Live updates announce only meaningful state transitions to avoid screen-reader noise.

At the interface boundary, ViewState records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/cases?cursor=... must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event UserReviewOpened must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

16.3.2 Time and number presentation

The server stores UTC; the UI presents workspace-local times with timezone labels. Locale selection changes display, not event ordering or durable API representations.

At the interface boundary, ReviewForm records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/cases/{caseId}/evidence must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event UserReviewOpened must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

16.4 Component and Contract Register

The following bounded-context register identifies implementation ownership and the minimum verification surface for this chapter. It is intentionally specific enough to support a backlog of interface-level tests.

Component / interface	Contract role	Required invariant
ViewState	Owner aggregate	UUIDv7 + tenant scope
ReviewForm	Immutable derivative	SHA-256 source/ revision
EvidencePanel	Policy-bound control	Actor and role predicate
Notification	Operational ledger	Event ID + trace context
API surface	GET /v1/cases?cursor=...	OAuth audience + idempotency policy
Secondary API	GET /v1/cases/{caseId}/evidence	Schema contract / bounded errors
Published event	UserReviewOpened	Versioned envelope / outbox

16.5 Failure Modes and Acceptance Evidence

Failure scenario A: a duplicate UserReviewOpened arrives after a network retry. The consumer checks its event ledger and aggregate revision, records a duplicate outcome, and returns without reapplying the mutation. Failure scenario B: a caller changes tenant or document permissions between search and publication; the publish gate recomputes its authorization and rejects stale evidence.

Acceptance evidence: one audit record for the accepted state transition, stable error codes for denied operations, tenant-scoped traces, and an implementation test proving this chapter invariant: A reviewer must be able to inspect source evidence before approval.

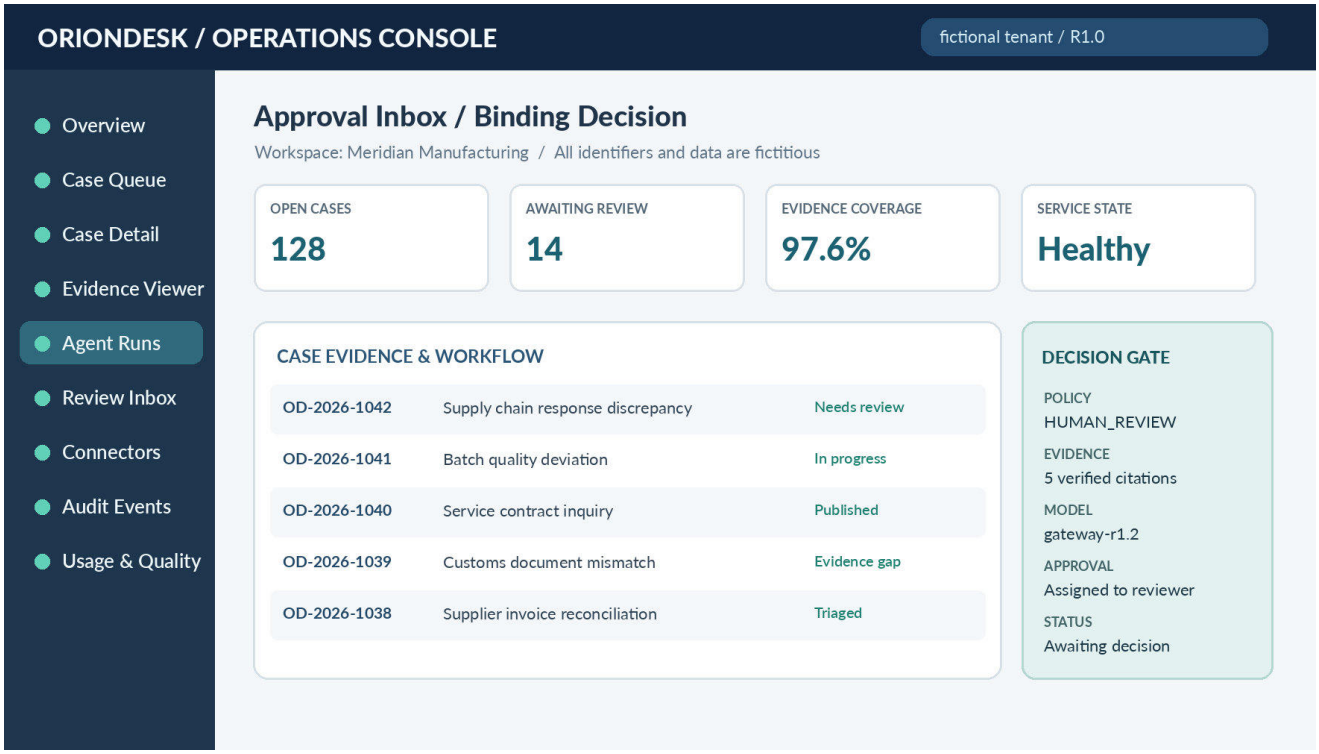


Figure 16.2 - representative operator view for the controlled scenario described in Chapter 16.

17 Application Security and Data Governance

Security is enforced in identity, ingestion, retrieval, tools, model context and operations, with auditable controls for data lifecycle.

NORMATIVE INVARIANT No model or tool call may receive secrets outside its declared scope.

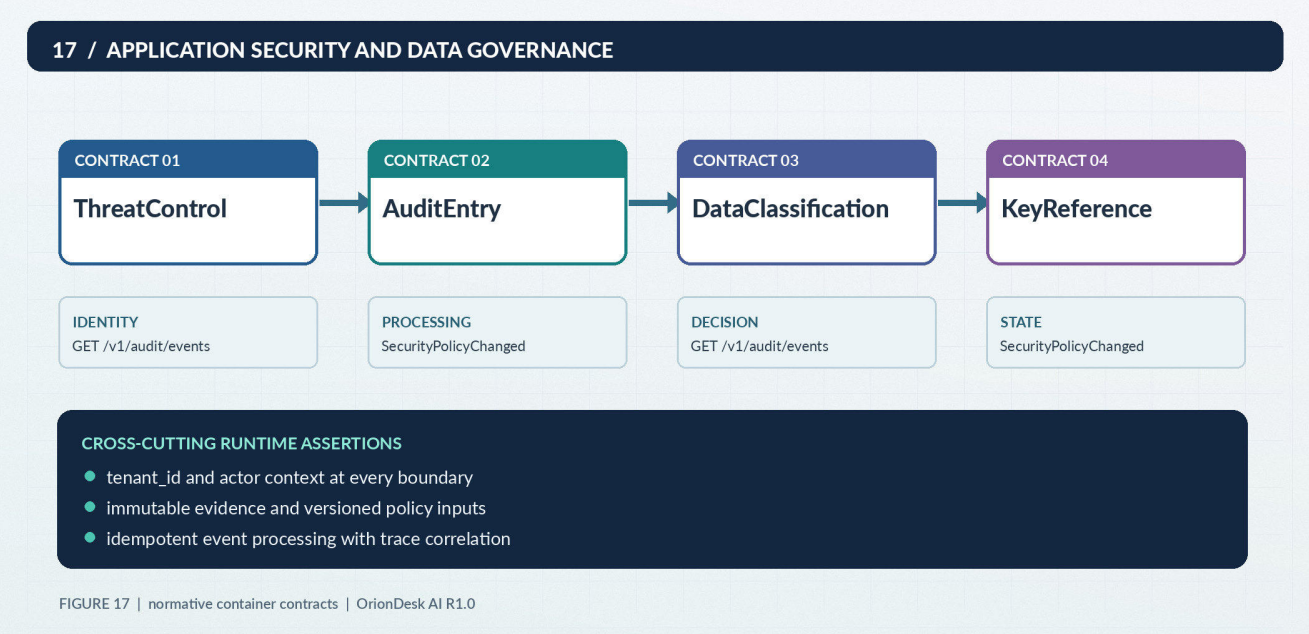


Figure 17.1 - logical components, boundary contracts and control assertions for application security and data governance.

17.1 Threat Model

17.1.1 Trust-boundary threats

Threats include cross-tenant IDOR, connector token exfiltration, prompt injection, malicious file parsing, tool argument forgery and approval replay. Each has a preventive control and a negative test.

At the interface boundary, ThreatControl records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/audit/events must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event SecurityPolicyChanged must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

17.1.2 Prompt and retrieval attacks

Untrusted content is visibly delimited, retrieved chunks carry provenance, and the planner receives only allowlisted tool names. Evidence cannot smuggle new system instructions or unrestricted network destinations.

At the interface boundary, AuditEntry records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/security/holds must validate input before

allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event SecurityPolicyChanged must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

17.2 Data Classification and Privacy

17.2.1 Information classes

Data classes are PUBLIC, INTERNAL, CONFIDENTIAL and RESTRICTED. The model route, log redaction, retention and approval policy depend on the maximum class of any material included in a run.

At the interface boundary, DataClassification records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/audit/events must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event SecurityPolicyChanged must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

17.2.2 PII minimization

Extraction tags likely personal data and the gateway redacts nonessential fields before provider invocation where policy permits. Logs capture token counts and digests, not entire prompts by default.

At the interface boundary, KeyReference records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/security/holds must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event SecurityPolicyChanged must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

Design checkpoint 17.2: stateful components must reject stale or unauthorized writes before publishing SecurityPolicyChanged; integration tests assert that rejected actions leave business state unchanged.

17.3 Audit and Cryptographic Controls

17.3.1 Immutable audit ledger

Audit entries are append-only, chained with batch hashes and exported to independently controlled retention storage. Operators may query but not alter historical review decisions.

At the interface boundary, ThreatControl records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/audit/events must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event SecurityPolicyChanged must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

17.3.2 Key and secret rotation

Application secrets remain in a key vault with managed identity access. Encryption keys rotate on defined policy without requiring bulk re-encryption in the request path.

At the interface boundary, AuditEntry records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/security/holds must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event SecurityPolicyChanged must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

17.4 Component and Contract Register

The following bounded-context register identifies implementation ownership and the minimum verification surface for this chapter. It is intentionally specific enough to support a backlog of interface-level tests.

Component / interface	Contract role	Required invariant
ThreatControl	Owner aggregate	UUIDv7 + tenant scope
AuditEntry	Immutable derivative	SHA-256 source/ revision
DataClassification	Policy-bound control	Actor and role predicate
KeyReference	Operational ledger	Event ID + trace context
API surface	GET /v1/audit/events	OAuth audience + idempotency policy
Secondary API	POST /v1/security/holds	Schema contract / bounded errors
Published event	SecurityPolicyChanged	Versioned envelope / outbox

17.5 Failure Modes and Acceptance Evidence

Failure scenario A: a duplicate SecurityPolicyChanged arrives after a network retry. The consumer checks its event ledger and aggregate revision, records a duplicate outcome, and returns without reapplying the mutation. Failure scenario B: a caller changes tenant or document permissions between search and publication; the publish gate recomputes its authorization and rejects stale evidence.

Acceptance evidence: one audit record for the accepted state transition, stable error codes for denied operations, tenant-scoped traces, and an implementation test proving this chapter invariant: No model or tool call may receive secrets outside its declared scope.

18 Observability, Cost and Service Reliability

The platform offers correlated diagnostics across API, workflow, search and model layers while controlling telemetry privacy and model spend.

NORMATIVE INVARIANT Diagnostic traces must not contain user documents or API secrets.

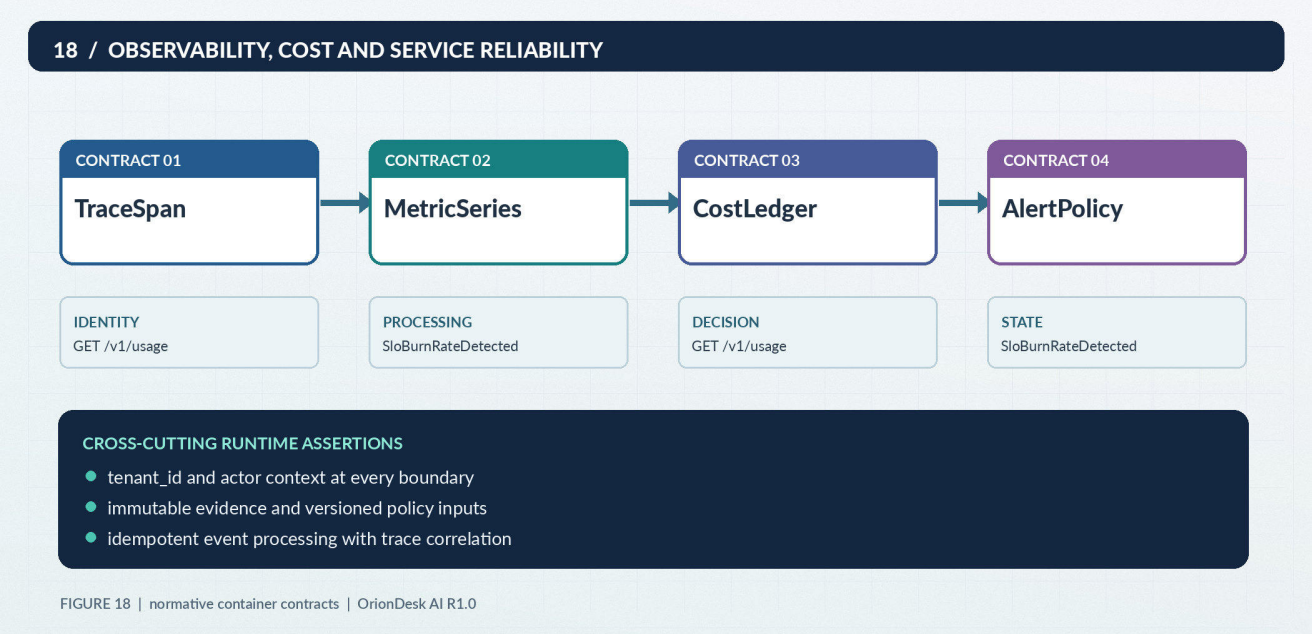


Figure 18.1 - logical components, boundary contracts and control assertions for observability, cost and service reliability.

18.1 Telemetry Model

18.1.1 Distributed traces

Every request carries trace_id and correlation_id; child spans represent DB, connector, retrieval, model and approval stages. Trace attributes contain identifiers and policy outcomes, never full document content.

At the interface boundary, TraceSpan records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/usage must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event SloBurnRateDetected must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

18.1.2 Metrics taxonomy

Golden signals include request rate, error rate, latency and saturation. AI-specific signals include grounding pass rate, retrieval empty rate, provider throttling, token use and approval backlog age.

At the interface boundary, MetricSeries records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /internal/metrics must validate input before

allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event SloBurnRateDetected must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

18.2 SLO and Alert Rules

18.2.1 Service objectives

The public API availability target is 99.9% monthly; case-create P95 is under 300 ms for the defined load. Search P95 is under 1.5 s excluding remote connector fetch; model generation latency is measured separately.

At the interface boundary, CostLedger records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/usage must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event SloBurnRateDetected must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

18.2.2 Actionable alerts

Pages are reserved for user-impacting incidents such as failure budgets, stale ACL propagation or missing approval enforcement. Routine token-spend anomalies create tickets with owner and threshold.

At the interface boundary, AlertPolicy records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /internal/metrics must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event SloBurnRateDetected must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

Design checkpoint 18.2: stateful components must reject stale or unauthorized writes before publishing SloBurnRateDetected; integration tests assert that rejected actions leave business state unchanged.

18.3 FinOps and Auditability

18.3.1 Per-tenant attribution

Model invocations, embeddings, storage and indexing usage carry workspace cost centers and model deployment versions. Daily rollups show budget, forecast and rejected excess requests.

At the interface boundary, TraceSpan records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/usage must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event SloBurnRateDetected must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

18.3.2 Retention-safe diagnostics

Diagnostic logs have a 30-day default TTL; security audit logs follow a distinct seven-year policy in this fictional design. A purge records completion receipts and legal-hold exceptions.

At the interface boundary, MetricSeries records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /internal/metrics must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event SloBurnRateDetected must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

18.4 Component and Contract Register

The following bounded-context register identifies implementation ownership and the minimum verification surface for this chapter. It is intentionally specific enough to support a backlog of interface-level tests.

Component / interface	Contract role	Required invariant
TraceSpan	Owner aggregate	UUIDv7 + tenant scope
MetricSeries	Immutable derivative	SHA-256 source/ revision
CostLedger	Policy-bound control	Actor and role predicate
AlertPolicy	Operational ledger	Event ID + trace context
API surface	GET /v1/usage	OAuth audience + idempotency policy
Secondary API	GET /internal/metrics	Schema contract / bounded errors
Published event	SloBurnRateDetected	Versioned envelope / outbox

18.5 Failure Modes and Acceptance Evidence

Failure scenario A: a duplicate SloBurnRateDetected arrives after a network retry. The consumer checks its event ledger and aggregate revision, records a duplicate outcome, and returns without reapplying the mutation. Failure scenario B: a caller changes tenant or document permissions between search and publication; the publish gate recomputes its authorization and rejects stale evidence.

Acceptance evidence: one audit record for the accepted state transition, stable error codes for denied operations, tenant-scoped traces, and an implementation test proving this chapter invariant: Diagnostic traces must not contain user documents or API secrets.

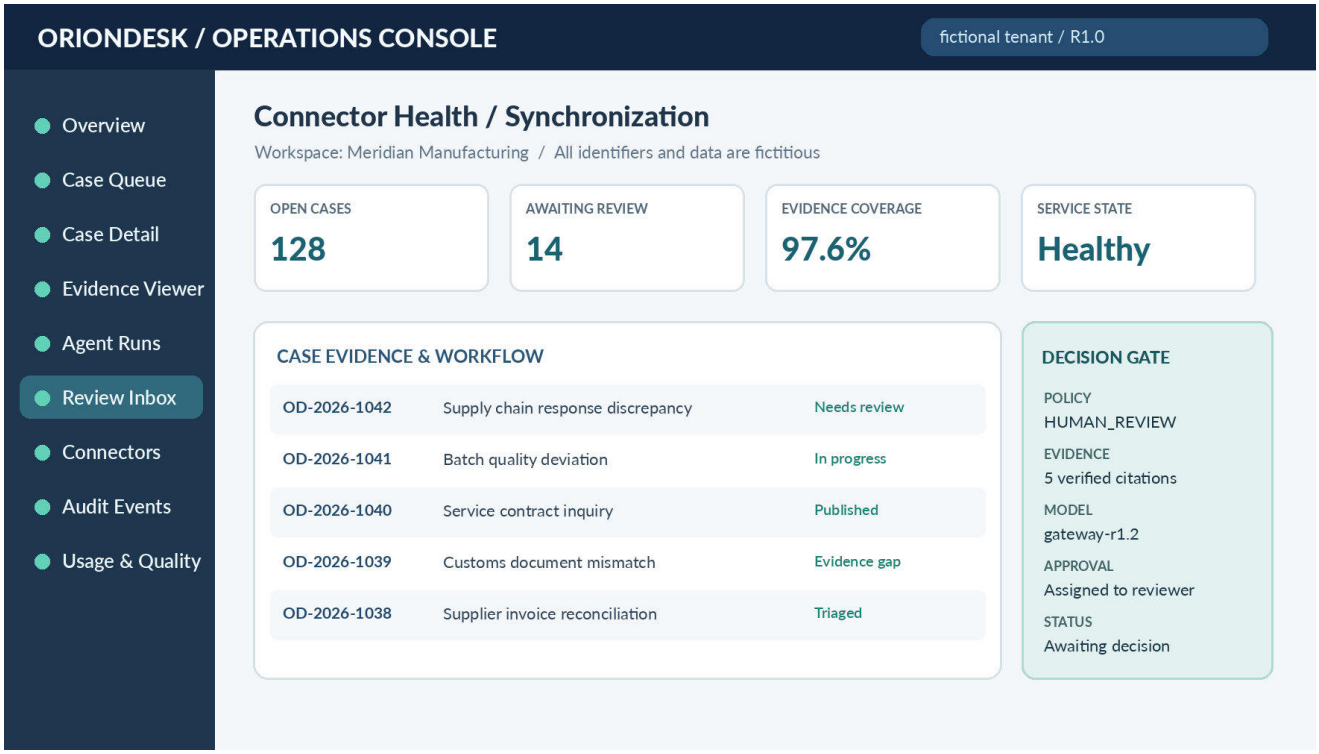


Figure 18.2 - representative operator view for the controlled scenario described in Chapter 18.

19 Performance, Capacity and Resilience

Capacity targets are derived from a repeatable workload envelope and include queue elasticity, provider limits and explicit graceful degradation.

NORMATIVE INVARIANT Degraded modes shall never bypass approval or authorization checks.

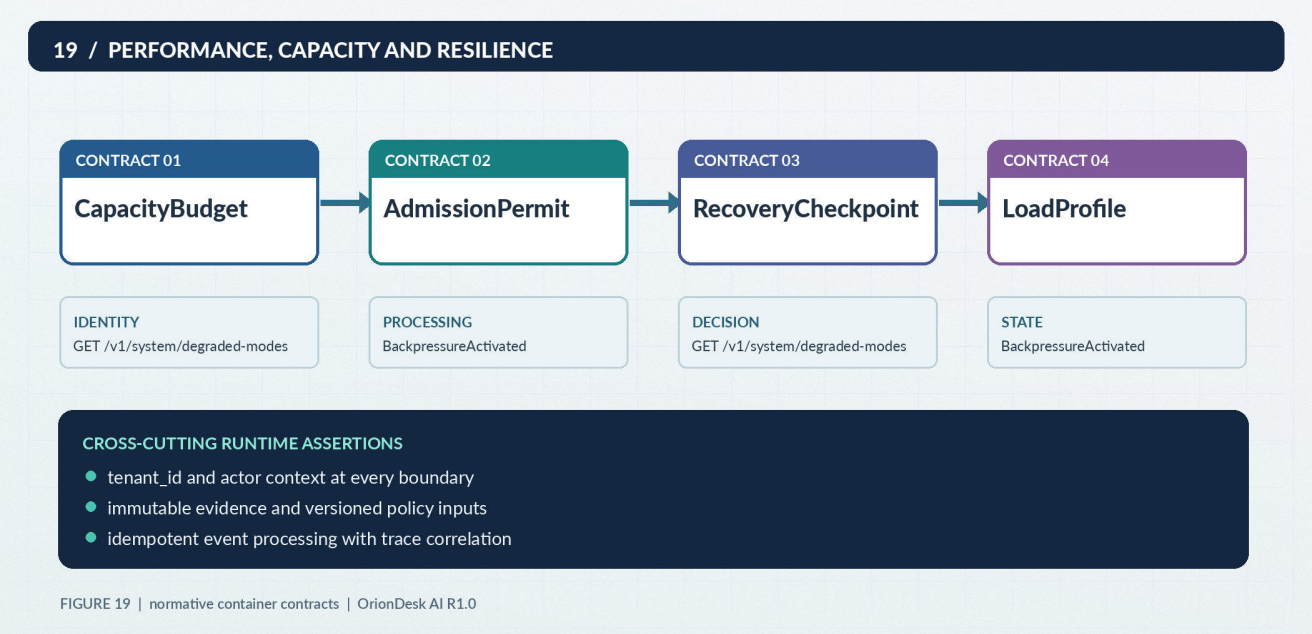


Figure 19.1 - logical components, boundary contracts and control assertions for performance, capacity and resilience.

19.1 Workload and Capacity

19.1.1 Reference traffic

The reference load is 2,000 active daily users, 60 requests per second steady state, 180 requests per second burst, 100,000 indexed documents per tenant maximum and 20 concurrent AI runs per large tenant.

At the interface boundary, CapacityBudget records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/system/degraded-modes must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event BackpressureActivated must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

19.1.2 Storage and index sizing

The model tracks raw files, normalized text, chunk vectors and replication overhead separately. A typical 1 MB source yields approximately 40-120 chunks, depending on content and parser quality.

At the interface boundary, AdmissionPermit records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /internal/capacity must validate

input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event BackpressureActivated must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

19.2 Backpressure and Quotas

19.2.1 Queue-aware throttling

New AI runs are admitted only if workspace tokens, queue age and provider capacity satisfy thresholds. Throttled clients receive 429 plus Retry-After, while saved cases remain available.

At the interface boundary, RecoveryCheckpoint records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/system/degraded-modes must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event BackpressureActivated must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

19.2.2 Graceful degradation

If generation is unavailable, evidence search and manual case editing remain online. If the vector index is degraded, lexical retrieval may continue with a visible reduced-quality flag.

At the interface boundary, LoadProfile records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /internal/capacity must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event BackpressureActivated must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

Design checkpoint 19.2: stateful components must reject stale or unauthorized writes before publishing BackpressureActivated; integration tests assert that rejected actions leave business state unchanged.

19.3 Recovery Design

19.3.1 Backup and restore

PostgreSQL continuous backups target RPO <=15 minutes and RTO <=4 hours for the reference recovery profile. Object versions and index rebuild recipes are tested together.

At the interface boundary, CapacityBudget records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/system/degraded-modes must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event BackpressureActivated must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

19.3.2 Chaos validation

Fault-injection exercises cover provider 429 storms, lost worker heartbeats, duplicate events, object access failures and primary-region outage; acceptance measures both safety and recovery time.

At the interface boundary, AdmissionPermit records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /internal/capacity must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event BackpressureActivated must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

19.4 Component and Contract Register

The following bounded-context register identifies implementation ownership and the minimum verification surface for this chapter. It is intentionally specific enough to support a backlog of interface-level tests.

Component / interface	Contract role	Required invariant
CapacityBudget	Owner aggregate	UUIDv7 + tenant scope
AdmissionPermit	Immutable derivative	SHA-256 source/ revision
RecoveryCheckpoint	Policy-bound control	Actor and role predicate
LoadProfile	Operational ledger	Event ID + trace context
API surface	GET /v1/system/degraded-modes	OAuth audience + idempotency policy
Secondary API	GET /internal/capacity	Schema contract / bounded errors
Published event	BackpressureActivated	Versioned envelope / outbox

19.5 Failure Modes and Acceptance Evidence

Failure scenario A: a duplicate BackpressureActivated arrives after a network retry. The consumer checks its event ledger and aggregate revision, records a duplicate outcome, and returns without reapplying the mutation. Failure scenario B: a caller changes tenant or document permissions between search and publication; the publish gate recomputes its authorization and rejects stale evidence.

Acceptance evidence: one audit record for the accepted state transition, stable error codes for denied operations, tenant-scoped traces, and an implementation test proving this chapter invariant: Degraded modes shall never bypass approval or authorization checks.

20 Deployment, Configuration and Release Engineering

Infrastructure and application changes are promoted as reproducible artifacts with policy checks, staged traffic and rollback criteria.

NORMATIVE INVARIANT The deployed binary, prompt and policy versions must be reconstructible.

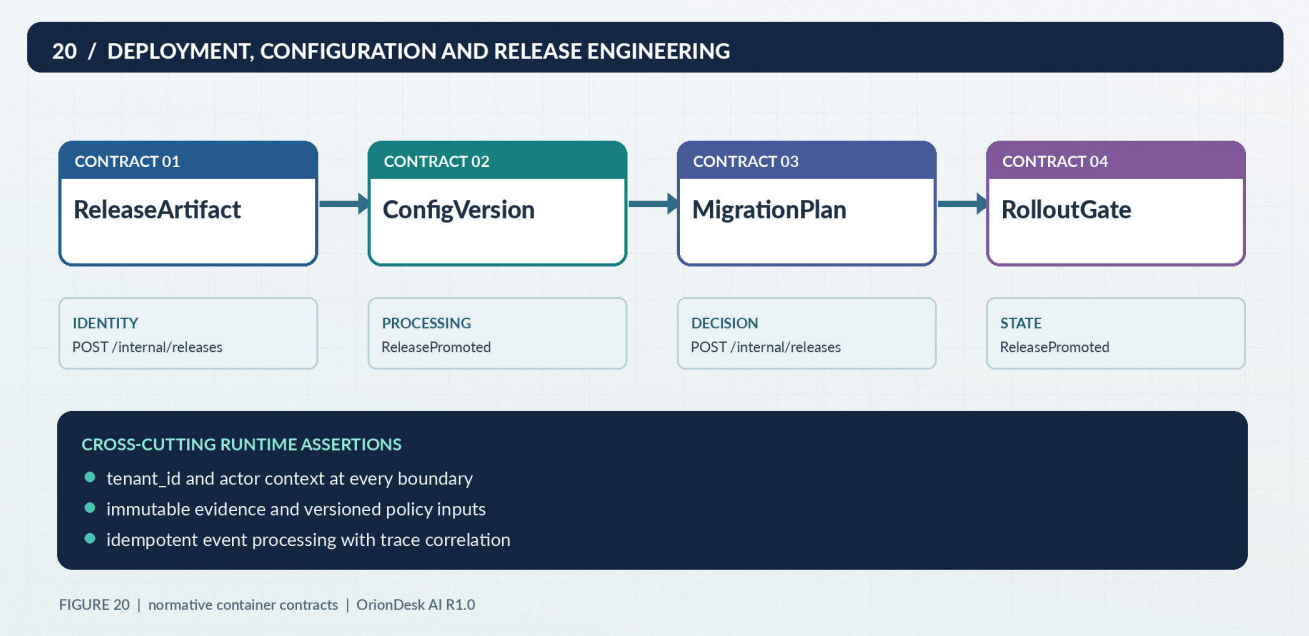


Figure 20.1 - logical components, boundary contracts and control assertions for deployment, configuration and release engineering.

20.1 Infrastructure as Code

20.1.1 Declarative resources

Terraform or Bicep declares network, managed identity, databases, storage, queues, search, monitoring and secret-vault bindings. Shared modules expose only documented inputs and outputs.

At the interface boundary, ReleaseArtifact records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /internal/releases must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event ReleasePromoted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

20.1.2 Configuration taxonomy

Nonsecret defaults live in source control; environment values are signed deployment configuration; credentials and encryption keys live only in vault-backed secret references.

At the interface boundary, ConfigVersion records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /internal/releases/{releaseId} must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event ReleasePromoted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

20.2 CI/CD and Supply Chain

20.2.1 Build and attestation

CI runs static analysis, dependency scanning, unit and contract tests, generates SBOM and signs container images. Production deploys only digests verified against an allowed build identity.

At the interface boundary, MigrationPlan records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /internal/releases must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event ReleasePromoted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

20.2.2 Database rollout

Predeploy migrations are backward compatible, traffic is canaried, and postdeploy enforcement runs after old replicas drain. Rollback plans specify whether writes performed by the new binary remain readable.

At the interface boundary, RolloutGate records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /internal/releases/{releaseId} must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event ReleasePromoted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

Design checkpoint 20.2: stateful components must reject stale or unauthorized writes before publishing ReleasePromoted; integration tests assert that rejected actions leave business state unchanged.

20.3 Release Decision Gates

20.3.1 Canary criteria

A canary compares latency, errors, authorization denials and AI-quality regression metrics against the baseline. Regression triggers automated traffic rollback, not a database down-migration.

At the interface boundary, ReleaseArtifact records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /internal/releases must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event ReleasePromoted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

20.3.2 Operator sign-off

Security and SRE validate external egress, secret handling, backup status and alert routing before promotion. A release record binds image digest, schemas, prompts and model routing policy.

At the interface boundary, ConfigVersion records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /internal/releases/{releaseId} must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event ReleasePromoted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

20.4 Component and Contract Register

The following bounded-context register identifies implementation ownership and the minimum verification surface for this chapter. It is intentionally specific enough to support a backlog of interface-level tests.

Component / interface	Contract role	Required invariant
ReleaseArtifact	Owner aggregate	UUIDv7 + tenant scope
ConfigVersion	Immutable derivative	SHA-256 source/ revision
MigrationPlan	Policy-bound control	Actor and role predicate
RolloutGate	Operational ledger	Event ID + trace context
API surface	POST /internal/releases	OAuth audience + idempotency policy
Secondary API	GET /internal/releases/{releaseId}	Schema contract / bounded errors
Published event	ReleasePromoted	Versioned envelope / outbox

20.5 Failure Modes and Acceptance Evidence

Failure scenario A: a duplicate ReleasePromoted arrives after a network retry. The consumer checks its event ledger and aggregate revision, records a duplicate outcome, and returns without reapplying the mutation. Failure scenario B: a caller changes tenant or document permissions between search and publication; the publish gate recomputes its authorization and rejects stale evidence.

Acceptance evidence: one audit record for the accepted state transition, stable error codes for denied operations, tenant-scoped traces, and an implementation test proving this chapter invariant: The deployed binary, prompt and policy versions must be reconstructible.

21 Test Strategy and Quality Evaluation

Test coverage combines deterministic software contracts, negative security cases and probabilistic AI evaluations without conflating model quality with correctness.

NORMATIVE INVARIANT Critical isolation and approval tests must pass with zero exceptions.

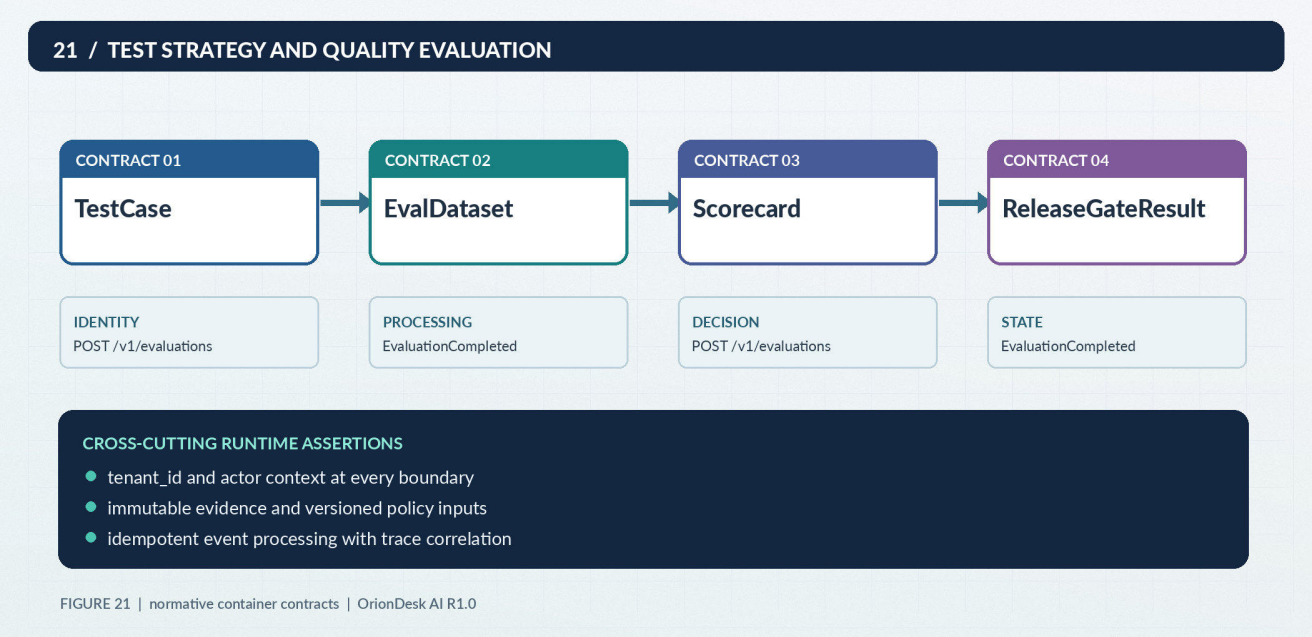


Figure 21.1 - logical components, boundary contracts and control assertions for test strategy and quality evaluation.

21.1 Deterministic Verification

21.1.1 Unit and contract tests

State transitions, idempotency, tenant filters, approval hashes, retry semantics and schema compatibility are exercised without live model calls. Consumer-driven contracts pin provider-facing adapters.

At the interface boundary, TestCase records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/evaluations must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event EvaluationCompleted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

21.1.2 Integration and failure injection

A disposable environment tests PostgreSQL transactions, outbox replay, source ACL revocation, delayed search indexing and object purge. Randomized retries must leave one accepted business outcome.

At the interface boundary, EvalDataset records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/evaluations/{evaluationId} must validate input

before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event EvaluationCompleted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

21.2 AI Evaluation Harness

21.2.1 Reference evaluation corpus

The dataset has 1,200 synthetic, permission-controlled cases spanning retrieval, refusal, ambiguity and adversarial evidence. Every example stores expected citation sets and decision outcomes.

At the interface boundary, Scorecard records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/evaluations must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event EvaluationCompleted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

21.2.2 Score thresholds

Grounded citation precision target is >=0.97, unsupported-claim rate <=0.02 and high-risk policy recall 1.00 on the frozen safety suite. Confidence intervals and distribution shift are reported by domain.

At the interface boundary, ReleaseGateResult records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/evaluations/{evaluationId} must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event EvaluationCompleted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

Design checkpoint 21.2: stateful components must reject stale or unauthorized writes before publishing EvaluationCompleted; integration tests assert that rejected actions leave business state unchanged.

21.3 Acceptance and Release Gates

21.3.1 End-to-end scenarios

Acceptance flows include create -> ingest -> retrieve -> draft -> review -> publish, a rejected draft rework, poisoned document quarantine and cross-tenant search denial.

At the interface boundary, TestCase records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/evaluations must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event EvaluationCompleted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

21.3.2 Regression management

Prompts and models can be rolled forward independently but require re-evaluation. Low statistical confidence is a blocking release outcome rather than evidence of equivalence.

At the interface boundary, EvalDataset records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path GET /v1/evaluations/{evaluationId} must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event EvaluationCompleted must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

21.4 Component and Contract Register

The following bounded-context register identifies implementation ownership and the minimum verification surface for this chapter. It is intentionally specific enough to support a backlog of interface-level tests.

Component / interface	Contract role	Required invariant
TestCase	Owner aggregate	UUIDv7 + tenant scope
EvalDataset	Immutable derivative	SHA-256 source/ revision
Scorecard	Policy-bound control	Actor and role predicate
ReleaseGateResult	Operational ledger	Event ID + trace context
API surface	POST /v1/evaluations	OAuth audience + idempotency policy
Secondary API	GET /v1/evaluations/{evaluationId}	Schema contract / bounded errors
Published event	EvaluationCompleted	Versioned envelope / outbox

21.5 Failure Modes and Acceptance Evidence

Failure scenario A: a duplicate EvaluationCompleted arrives after a network retry. The consumer checks its event ledger and aggregate revision, records a duplicate outcome, and returns without reapplying the mutation. Failure scenario B: a caller changes tenant or document permissions between search and publication; the publish gate recomputes its authorization and rejects stale evidence.

Acceptance evidence: one audit record for the accepted state transition, stable error codes for denied operations, tenant-scoped traces, and an implementation test proving this chapter invariant: Critical isolation and approval tests must pass with zero exceptions.

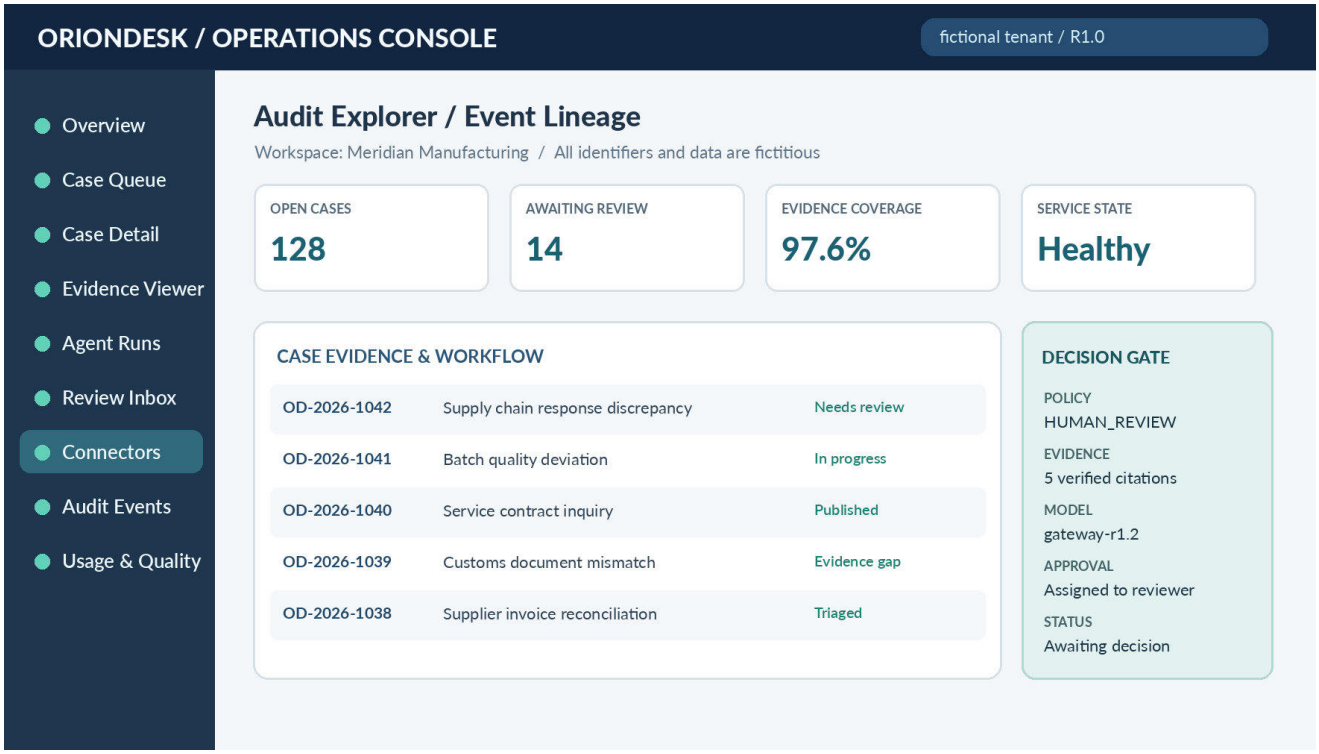


Figure 21.2 - representative operator view for the controlled scenario described in Chapter 21.

22 Operations, Migration and Runbooks

An operationally complete design documents how to adopt, recover, audit and retire the system safely.

NORMATIVE INVARIANT Delete and export operations require two independent approval checks.



Figure 22.1 - logical components, boundary contracts and control assertions for operations, migration and runbooks.

22.1 Initial Data Onboarding

22.1.1 Tenant provisioning

Provisioning creates workspace policy, encryption references, role bindings, quotas and connector stubs as one idempotent workflow. Incomplete provisioning is visible and blocks connector sync.

At the interface boundary, Runbook records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/workspaces/{workspaceId}/export must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event TenantDeletionVerified must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

22.1.2 Backfill and reconciliation

Historic documents are ingested in bounded windows with stable source IDs and per-batch reconciliation receipts. Search readiness is signaled by index coverage, not merely queue emptiness.

At the interface boundary, ProvisioningJob records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/workspaces/{workspaceId}/delete must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented

retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event TenantDeletionVerified must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

22.2 Incident Runbooks

22.2.1 Model provider outage

Disable new generation admission, keep manual case and evidence workflows available, display degraded status and page on-call only when the availability budget is impacted.

At the interface boundary, ExportManifest records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/workspaces/{workspaceId}/export must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event TenantDeletionVerified must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

22.2.2 Suspected ACL leak

Suspend affected index aliases, revoke cached evidence, preserve audit traces and execute scoped replay of ACL revisions. Re-enable search only after negative access tests pass.

At the interface boundary, PurgeReceipt records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/workspaces/{workspaceId}/delete must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event TenantDeletionVerified must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

Design checkpoint 22.2: stateful components must reject stale or unauthorized writes before publishing TenantDeletionVerified; integration tests assert that rejected actions leave business state unchanged.

22.3 Decommission and Exit

22.3.1 Tenant export

An authorized export packages case metadata, approved artifacts, source references and audit manifests with checksums. Secrets and internal model prompts are excluded by design.

At the interface boundary, Runbook records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/workspaces/{workspaceId}/export must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event TenantDeletionVerified must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

22.3.2 Verified deletion

The deletion workflow enforces legal hold, writes tombstones, removes blobs and index entries, and records completion receipts. Data subject access requests are handled through the same inventory.

At the interface boundary, ProvisioningJob records shall carry tenant_id, revision, actor_id, occurred_at and a correlation ID wherever the operation changes durable state. The request path POST /v1/workspaces/{workspaceId}/delete must validate input before allocating a long-running operation; if a dependency is unavailable, callers receive a documented retryable error or a persisted asynchronous job identifier, never an ambiguous success.

Engineering verification for this component includes a positive test, a cross-tenant denial test, a duplicate/replay test and an evidence-retention test. The event TenantDeletionVerified must be visible through correlated logs and the audit record without placing source document text in diagnostic telemetry.

22.4 Component and Contract Register

The following bounded-context register identifies implementation ownership and the minimum verification surface for this chapter. It is intentionally specific enough to support a backlog of interface-level tests.

Component / interface	Contract role	Required invariant
Runbook	Owner aggregate	UUIDv7 + tenant scope
ProvisioningJob	Immutable derivative	SHA-256 source/ revision
ExportManifest	Policy-bound control	Actor and role predicate
PurgeReceipt	Operational ledger	Event ID + trace context
API surface	POST /v1/workspaces/{workspaceId}/export	OAuth audience + idempotency policy
Secondary API	POST /v1/workspaces/{workspaceId}/delete	Schema contract / bounded errors
Published event	TenantDeletionVerified	Versioned envelope / outbox

22.5 Failure Modes and Acceptance Evidence

Failure scenario A: a duplicate TenantDeletionVerified arrives after a network retry. The consumer checks its event ledger and aggregate revision, records a duplicate outcome, and returns without reapplying the mutation. Failure scenario B: a caller changes tenant or document permissions between search and publication; the publish gate recomputes its authorization and rejects stale evidence.

Acceptance evidence: one audit record for the accepted state transition, stable error codes for denied operations, tenant-scoped traces, and an implementation test proving this chapter invariant: Delete and export operations require two independent approval checks.

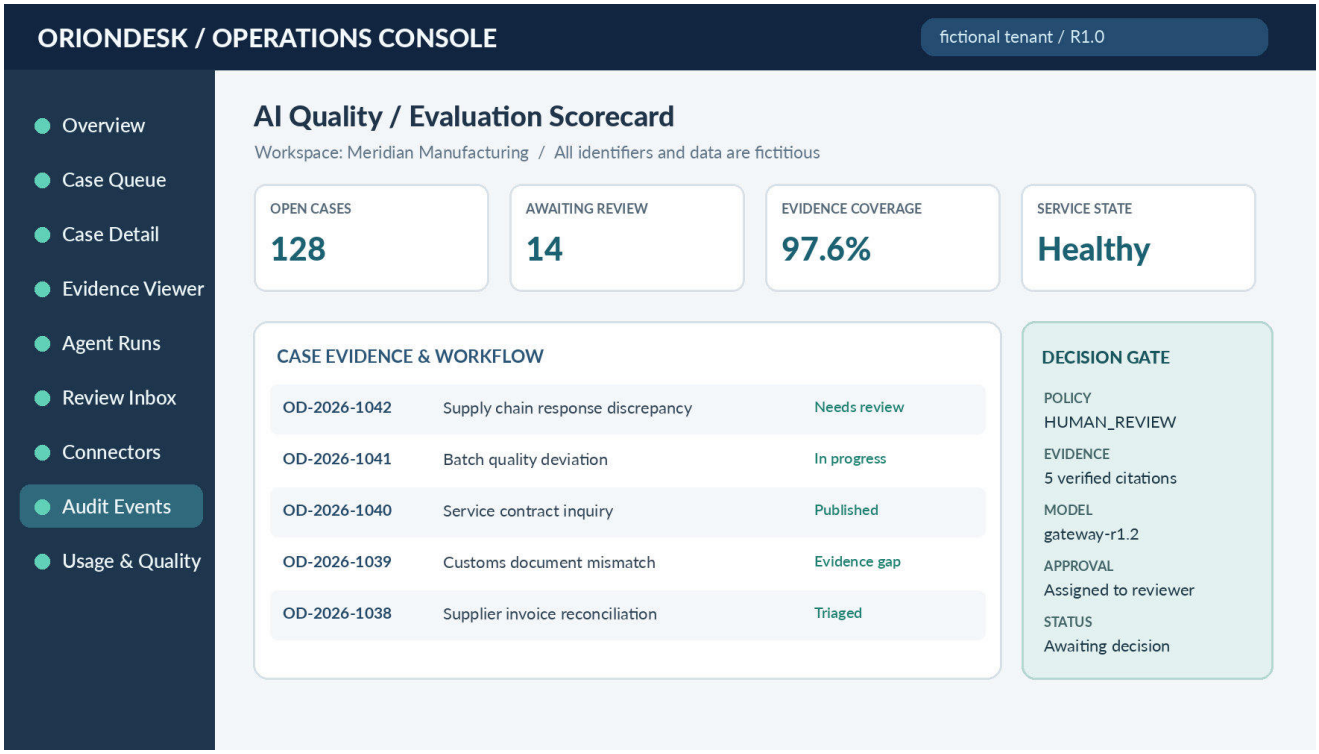


Figure 22.2 - representative operator view for the controlled scenario described in Chapter 22.

Appendix A Domain State and API Catalog

The following schemas and examples are a reference contract. Production implementations shall generate OpenAPI and protobuf definitions from repository-controlled IDL. All examples use placeholder identifiers and fictional customers.

A.1 Case and Run States

Aggregate	Allowed states	Transition guard
Case	NEW / TRIAGED / IN_PROGRESS / PENDING_APPROVAL / RESOLVED / CLOSED	Role, revision and approval requirements
Run	REQUESTED / RETRIEVING / GENERATING / POLICY_CHECK / AWAITING_REVIEW / PUBLISHED / FAILED	Workflow checkpoint + runtime budget
Document	ACCEPTED / SCANNING / EXTRACTING / INDEXING / READY / QUARANTINED	Virus scan and quality gate
Review	ASSIGNED / OPENED / APPROVED / REJECTED / EXPIRED	Actor, content hash and separation of duties

A.2 REST Resource Register

Verb	Path	Scope	Result	Behavior
POST	/v1/cases	Analyst	201	Creates case with idempotency key
GET	/v1/cases/{caseId}	Analyst / Reviewer	200	Reads authorized current case revision
PATCH	/v1/cases/{caseId}	Owner	200 / 409	Mutates with If-Match revision
POST	/v1/cases/{caseId}/attachments	Analyst	202	Creates ingestion operation
POST	/v1/cases/{caseId}/runs	Analyst	202	Starts bounded AI workflow
GET	/v1/runs/{runId}	Analyst / Reviewer	200	Returns stages and evidence metadata
GET	/v1/streams/runs/{runId}	Analyst / Reviewer	200	SSE resume with Last-Event-ID
POST	/v1/approvals/{approvalId}/decision	Reviewer	200 / 409	Binds action to reviewed hash
POST	/v1/connectors/{connectorId}/sync	Admin	202	Starts incremental source sync
POST	/v1/search	Member	200	ACL-filtered lexical + semantic evidence
GET	/v1/audit/events	Auditor	200	Cursor-paginated immutable log
GET	/v1/usage	Admin	200	Costs, quotas and trend estimates
POST	/v1/evaluations	Admin	202	Starts frozen benchmark evaluation
POST	/v1/workspaces/{workspaceId}/export	Admin + approver	202	Controlled export with manifest
POST	/v1/workspaces/{workspaceId}/delete	Admin + approver	202	Legal-hold-safe deletion

A.3 Canonical Error Envelope

```
HTTP/1.1 409 Conflict
Content-Type: application/json
{
  "error": {
    "code": "CASE_VERSION_CONFLICT",
    "message": "Case revision no longer matches.",
    "correlation_id": "trace_01HZZ_EXAMPLE",
    "retryable": false,
    "details": {"expected_revision": 7, "actual_revision": 8}
  }
}
```

The error object may contain safe structured validation details; it must not include connector credentials, full prompts, retrieved documents, or unauthorized resource existence.

Appendix B Canonical Data Definitions

B.1 Relational Entity Catalog

Entity	Selected fields	Primary constraint
tenants	id, slug, plan, region, created_at	unique(slug)
workspaces	id, tenant_id, policy_version, quota	RLS tenant scope
cases	id, tenant_id, workspace_id, status, revision	unique(tenant_id,id)
case_revisions	case_id, revision, patch, actor, at	append only
documents	id, workspace_id, source_id, sensitivity	source ACL enforced
document_versions	document_id, hash, parser_version, object_key	immutable
chunks	id, document_version_id, page, bbox, text_hash	source anchor
runs	id, case_id, status, plan_revision, budget	bounded state machine
run_steps	id, run_id, step_kind, status, checkpoint	idempotent step
evidence_sets	id, run_id, chunk_refs, acl_digest	publish validation
approval_tasks	id, run_id, reviewer_pool, artifact_hash	no self approval
approval_decisions	id, task_id, reviewer_id, decision, reason	immutable
audit_events	id, tenant_id, actor_id, action, digest	append only
outbox_events	event_id, tenant_id, aggregate_revision, payload	transactional outbox
connector_cursors	connector_id, cursor, watermark, retry_state	durable checkpoints
token_ledger	run_id, deployment_id, in_tokens, out_tokens	attributed cost
policy_evaluations	run_id, rule_version, input_digest, result	reproducible
deletion_receipts	tenant_id, object_ref, purge_time, actor	auditable purge

B.2 DDL Reference

```
CREATE TABLE cases (
  id UUID PRIMARY KEY,
  tenant_id UUID NOT NULL REFERENCES tenants(id),
  workspace_id UUID NOT NULL REFERENCES workspaces(id),
  status TEXT NOT NULL CHECK (status IN
    ('NEW','TRIAGED','IN_PROGRESS','PENDING_APPROVAL',
     'RESOLVED','CLOSED')),
  revision BIGINT NOT NULL DEFAULT 1,
  sensitivity TEXT NOT NULL DEFAULT 'INTERNAL',
  created_at TIMESTAMPTZ NOT NULL DEFAULT now(),
  updated_at TIMESTAMPTZ NOT NULL DEFAULT now(),
  UNIQUE (tenant_id, id)
);
ALTER TABLE cases ENABLE ROW LEVEL SECURITY;
CREATE POLICY tenant_scope ON cases USING (
  tenant_id = current_setting('app.tenant_id')::UUID
);
```

The database connection pool must reset scoped session variables after every transaction. Production DDL must additionally enforce workspace-tenancy membership via foreign keys or controlled write procedures.

Appendix C Event and Tool Protocols

C.1 Event Catalog

Event	Producer	Payload keys	Consumer action
CaseCreated	Case Service	Case ID / revision	Run classifier
DocumentNormalized	Ingestion	Version ID / source hash	Build index
SearchIndexCommitted	Indexer	Index generation / document revision	Invalidate query cache
AgentPlanApproved	Orchestrator	Run ID / plan hash	Dispatch plan steps
ApprovalDecisionRecorded	Policy Service	Task / actor / content hash	Validate publication
WorkflowStageAdvanced	Orchestrator	Run / stage / checkpoint	Resume consumers
AccessDenied	Policy Service	Principal / action / policy digest	Alert enrichment
TenantDeletionVerified	Retention Worker	Manifest ID / receipt hash	Close purge record

C.2 A2A Task Envelope and MCP Tool Contract

```
{
  "task_id": "019ac000-0000-7000-8000-000000000042",
  "tenant_id": "tenant_example_01",
  "capability": "research.grounded_search.v1",
  "input_schema": "schema://oriondesk/research-request/1",
  "deadline_at": "2026-11-09T08:00:00Z",
  "trace_id": "trace_example_01",
  "authorization_ref": "grant_readonly_14",
  "payload": {"case_id": "case_demo", "query": "..."}
}
```

```
MCP TOOL: knowledge.search@v1
INPUT:  {query: string, case_id: uuid, max_items: int<=10}
OUTPUT: {evidence_set_id: uuid, citations: Citation[]}
AUTHZ:  read:permitted_documents, tenant-scoped
EFFECT: read-only; no arbitrary URLs or filesystem access
```

Capability registration is discovery metadata only. Authorization remains a separate decision made with the invoking principal, workspace policy, tool scope and data classification.

Appendix D Threats, Controls and Verification

ID	Threat	Control	Negative verification
T-01	Cross-tenant resource guessing	RLS + domain resource guard	Attempt valid ID with foreign tenant token
T-02	Prompt-injected source text	Evidence delimiting + tool schema pinning	Embed hostile instructions in PDF paragraph
T-03	Stale reviewer action	Artifact-hash binding	Approve prior draft after revision
T-04	Malicious file content	Scan / sandbox / bounded parser	Upload polyglot PDF and zipped payload
T-05	Connector credential disclosure	Vault + redacted telemetry	Observe traces and provider requests
T-06	Unapproved model fallback	Allowed deployment registry	Simulate regional provider outage
T-07	Message replay	Idempotency and aggregate revision	Replay same event 100 times
T-08	ACL index staleness	ACL revision cache invalidation	Revoke source permission during search
T-09	Audit modification	Append-only hash-chain export	Attempt historical record edit
T-10	Unbounded agent recursion	Tool/step/time budget	Return mutually recursive tool hints
T-11	Excessive export access	Two-person approval + manifest	Try export as single Admin
T-12	Poisoned evaluation set	Dataset version + signed manifest	Replace expected score fixtures

D.1 Security Exit Criteria

Critical requirements SEC-001 through SEC-012 are release-blocking. A security-control owner reviews implementation evidence, independently reproduces negative cases and signs the release record. Unmitigated critical cross-tenant or approval-bypass findings prevent promotion regardless of model benchmark score.

Appendix E Verification Matrix and Test Data

Test ID	Scenario	Expected outcome
TST-001	Create case twice with same key	One case and identical response
TST-002	Reuse key with changed body	409 IDEMPOTENCY_CONFLICT
TST-003	Read foreign-tenant case	404-equivalent non-disclosing error
TST-004	Revoke source access after indexing	No forbidden evidence on next query
TST-005	Force model schema failure	MODEL_OUTPUT_INVALID; no publish
TST-006	Approve wrong artifact hash	Rejected as stale, audited
TST-007	Replay outbox message	Exactly one accepted business transition
TST-008	Fail provider with 429 burst	Capped retries; admitted load controlled
TST-009	Generate response with missing citations	Needs review or unsupported outcome
TST-010	Expire review task	No implicit approval; escalation recorded
TST-011	Open case using keyboard only	No blocked action, visible focus
TST-012	Region recovery exercise	RPO/RTO within stated limits
TST-013	Purge tenant under legal hold	Protected records retained and receipted
TST-014	Attempt arbitrary MCP tool invocation	DENY before dispatch
TST-015	Unsafe PDF payload	Quarantine, no indexing
TST-016	Canary with regressed safety score	Release gate blocks promotion

E.1 Test Fixture Principles

All identities, cases, documents and provider replies in this specification are synthetic. Fixtures cover successful, empty, mixed-permission, adversarial and malformed inputs. Every randomized test records its seed. Evaluation corpora are frozen, versioned and independently reviewed for leakage between training examples and acceptance data.

E.2 Minimum release test pack

The deployment pipeline runs unit tests, schema evolution tests, negative authorization tests, workflow replay tests, staging connector sync, visual accessibility checks, search recall benchmarks, grounding evaluations, policy-recall evaluations, load tests and disaster recovery drills. Test outputs are signed and referenced by release digest.

Appendix F Configuration and Runbook Examples

```
release: r1.0
workflow:
  max_plan_depth: 8
  max_tool_calls: 16
  run_timeout_seconds: 180
  replay_dedup_hours: 24
retrieval:
  max_candidate_chunks: 80
  max_selected_chunks: 10
  embed_dimension: 1536
  hybrid_rrf_k: 60
policy:
  auto_publish_classification: INTERNAL
  require_human_review_for: [HIGH_RISK, RESTRICTED]
  self_approval_allowed: false
storage:
  upload_limit_mb: 25
  user_data_region: primary-approved-region
observability:
  trace_sample_rate: 0.10
  diagnostic_retention_days: 30
  audit_retention_years: 7
```

F.1 Runbook: delayed document indexing

Stage	Operator action
Detect	Alert on queue oldest age and index backlog; find affected tenant and index generation.
Contain	Pause only the faulty connector or indexer shard; keep accepted source records durable.
Diagnose	Inspect event ID, outbox lag, parser flags, search throttling and source ACL revision.
Recover	Replay validated outbox records using a bounded operator-controlled job.
Verify	Compare source fingerprints to indexed versions, run denied-access probes and close incident.
Document	Link audit IDs, time window, blast radius, quality effect and preventative action.

F.2 Open implementation questions

Before implementation lock, select the supported cloud region, exact search provider, identity provider, approved model deployments, corporate retention policy and third-party connector permissions. Each selection must be recorded in a dated architecture decision rather than silently presumed by this synthetic baseline.

END OF CONTROLLED FICTIONAL DETAILED DESIGN SPECIFICATION • OD-AI-DDS-001 • R1.0